SL5 Novel Recommendations

Preliminary draft

NOVEMBER 2025

Lisa Thiergart

Luis Cosio

Yoav Tzfati

Peter Wagstaff

Guy

Philip Reiner

Table of Contents

About The Security Level 5 Task Force **6**
About This Document **7**
Supply Chain Security **8**
Overview 8
Minimize attack surface in critical software systems via architectural isolation and progressive access restriction 9
Review, prune, refactor, rewrite, or formally verify all external security-critical software 10
Review and audit the hardware supply chain for security-critical components using a trusted, diverse supplier base 11
Develop and deploy adversarially robust systems to verify data integrity 13
Continuously red team all supply chain processes 13
Bibliography 15
Network Security **18**
Overview 19
Connect network enclaves with inline network encryptors 20
Encrypt accelerator interconnect 21
Isolate powerful models on an air-gapped network 22
Maintain an additional air-gapped network for running unsigned code for R&D 23
Develop AI-enhanced cross-domain solutions 24
Bibliography 26
Appendix A 30
Machine Security **32**
Overview 33
Push for AI Accelerators to have stronger security features 34
Employ verified/measured boot on all devices with privileged access 35
Use simple devices to defer authorization away from complex systems 36
Support tamper-proof and tamper-evident enclosures that can envelop entire sensitive scopes 37
Design processes with planned adversarial injections 38
Bibliography 39
Physical Security **41**
Overview 42
Enforce two-person integrity (TPI) for all maintenance 43
Mandate body-worn cameras with obstruction alarms 44
Eliminate out-of-facility maintenance 45
Harden side-channel defenses (LED masking, additional noise generators and shielding display cables) 46
Perform pre-installation component X-ray verification 47
Bibliography 49
Personnel Security **51**

Overview 52
Implement Industry-Optimized Sensitivity Levels (Private Sector Clearance) 53
Develop and Enforce AI Agent Access Agreements and Boundaries 54
Continuous Behavioral Monitoring for Humans and AI 56
Decorrelate and diversify review of AI-generated outputs (internal use) 57
Continuous Red Teaming 58
Bibliography 60

About The Security Level 5 Task Force

Artificial General Intelligence (AGI) is on the horizon: many predict that artificial intelligence could advance toward AGI within the next one to three years, closely followed by superintelligence. We must ensure that these increasingly autonomous systems cannot be manipulated or overtaken by bad actors and nation-state adversaries. The national security stakes have never been higher.

As a project inside a 501(c)(3), the SL5 Task Force is collaborating with over 50 participants–including AI lab decision-makers, national security leaders, data center operators, chip providers, security researchers, program managers, and engineers, to develop a technical roadmap and standard for achieving Security Level 5 (SL5) in artificial intelligence: cyber, physical, insider, and supply chain security capable of withstanding operations from the most capable nation-state actors.

A safe future routes through strong security and containment of frontier AI development. Researchers at RAND Corporation developed a blueprint for protecting AI model weights from theft and misuse by malicious actors–ranging from opportunistic criminals to sophisticated nation-state operations. By mapping out thirty-eight distinct attack vectors and estimating the feasibility of exploitation for each, they identify five security levels that frontier AI organizations should look to achieve.

However, achieving Security Level 5 while also maintaining productivity and national competitiveness demands unprecedented coordination across the AI industry, hyperscalers, data center providers, international governments, and more. Current best practices for frontier AI organizations do not reach SL5. In fact, on the default path, SL5 will not be realized before automated AI R&D thresholds are reached.

In response to this challenge, the SL5 Task Force is running a multistakeholder sprint to identify gaps, develop solutions, and facilitate implementation. Led by Lisa Thiergart and Philip Reiner, the SL5 Task Force's mission is to "**create the optionality for U.S. AI Labs to reach Security Level 5 in the coming years, and to be able to activate SL5 within 3-6 months of choosing to do so**."

About This Document

This report is the SL5 Task Force's initial blueprint for reaching Security Level 5 (SL5), a set of security and containment measures intended to counter nation-state adversaries across supply-chain, network, machine, physical, and personnel security. It gathers implementable controls, cost-benefit analyses, and pilot concepts, presented as focused memos to help labs evaluate and apply specific protections rather than general principles.

Developed via a multistakeholder sprint with input from AI labs, national security leaders, data center operators, hardware providers, and security experts, the report identifies gaps in existing practices and proposes solutions that consider AI development needs. This preliminary work focuses on practical interventions that aim to maintain efficiency while addressing security risks from potential adversarial actions.

The report is structured into five domain memos—Machine Security, Network Security, Personnel Security, Physical Security, and Supply Chain Security—each designed to function independently while supporting an overall SL5 approach. Each memo starts with an Overview and Executive Summary for quick reference, followed by Top 5 Recommendations based on research and input. Further sections provide Research Reasoning on threats, Cost-Benefit evaluations of trade-offs, and Alternatives for different options. Relevant memos also suggest Pilot Projects, like benchmarks for AI-assisted code hardening or supply chain forecasting, to support testing and refinement. Each memo concludes with its own bibliography.

As preliminary work, this report provides a starting point for discussion and refinement, enabling labs to begin assessing SL5 feasibility within 3-6 months of deciding to pursue it.

Supply Chain Security

Overview

Executive Summary

The AI supply chain presents a major attack surface for frontier training operations [1]–[3]. Software supply chain attacks are among the cheapest and most scalable attacks for an external individual or nation-state to execute. While hardware attacks are more costly to orchestrate, they are feasible for well-resourced nation-state attackers at **Offensive Capability Level 5 (OC5)** [4], [5].

Whereas SL4 can plausibly be reached incrementally, SL5 can likely only or at least most quickly and cheaply be reached by a **radical reduction in the hardware and software stack that is trusted**, as well as a reduction of the volume of code that interfaces with critical components [6], [7] or is necessary for critical actions (this term for instance includes any processes touching model weights, hardware and software that trust is deferred to, etc.).

Since onshoring the chip supply chain in the coming years is particularly unrealistic, we think this can best be mitigated by investing in compensating controls, such as **investing in a strong, ideally on-chip, hardware root of trust in the next generation of AI chips** and exploring confidential computing and other chip security interventions mentioned in the machine security memo. These could include features such as those developed as part of the OpenTitan [8]–[13] project, though different vendors might have different preferred ways of implementing similar features. Other parts of the hardware supply chain can perhaps be audited and procured from trusted vendors [14], as discussed in the recommendations below.

Achieving a radical reduction in the software stack in the next three years without incurring unrealistic staffing expenses will involve a strong **reliance on untrusted Large Language Models (LLM) labor**[1] (i.e., LLMs we are not confident will not sabotage, self-exfiltrate or malfunction). There is a need to **differentially accelerate both the development of these defensive security capabilities** as well as **developing and deploying a mixed portfolio of oversight techniques [15]–[17] to guard the use of these models**. While the personnel memo discusses monitoring and oversight in particular, this memo calls for the differential acceleration of various defensive-dominant security tooling including how to safely use an SL4 model to accelerate the development of SL5 security infrastructure. We propose 5 actionable recommendations for AI labs and the AI industry to begin bridging the delta between SOTA and what is necessary to reach SL5.

Top 5 Recommendations

1. Minimize attack surface in critical software systems via architectural isolation and progressive access restriction
2. Review, prune, refactor, rewrite, or formally verify all external security-critical software
3. Review, minimize and audit the hardware supply chain for security-critical components
4. Develop and deploy adversarially robust systems to verify data integrity
5. Continuously red team all supply chain processes

[1] For SL5 planning, we suggest treating LLM assistance as untrusted-by-default in weight-adjacent workflows. This risk posture will be revisited in further work as the trust criteria of models in coding evolve. See related work [45], [46].

Minimize attack surface in critical software systems via architectural isolation and progressive access restriction

Explanation of Recommendation

Labs should establish architectural boundaries between systems based on their access to sensitive resources like frontier model weights, and where applicable architect these as rings of hardening [20]. Components with direct access to these resources must run with minimal, highly trusted software dependencies, while less sensitive systems can retain broader functionality. Access to sensitive resources should be provided only through **safe, narrow APIs that perform specific operations** (e.g., fine-tuning, quantization, inference) rather than allowing direct resource manipulation. This enables critical operations to run with a minimal software stack containing only essential, hardened components, while the broader R&D ecosystem—with its necessary but less-trusted dependencies—operates in isolated environments without direct access. Labs should **implement approval pipelines that assess new dependencies based on their proximity to sensitive resources (and ability to perform critical actions), security practices, codebase size, and necessity** [7], [19]. Additionally, **implementing APIs** can aid the implementation of progressive access restriction: **labs should minimize the number of staff, agents, services and other components with access to sensitive environments** (e.g., by establishing strict access quotas and reducing these over time, called "**seat management**" (progressively reducing and time-bounding privileged seats), which has been demonstrated by Cloudflare [21] and by an analogous process used by Google [20].

Research Reasoning

Every external package creates attack vectors through its code and transitive dependencies [18]. Our preliminary mapping identified hundreds of top-level software components across varying access levels, each bringing numerous transitive dependencies. The full ML software stack attack surface is likely infeasible to secure for weight-accessing systems. The solution combines architectural separation with aggressive dependency reduction—weight-accessing processes run minimal, self-sufficient code while R&D, monitoring, and CI/CD operate in separate environments with appropriate isolation.

Labs should implement multiple layers of separation—software-level API boundaries, physical host isolation, and network-level controls (as detailed in our Network Security recommendations)—to create defense-in-depth. Each additional layer reduces the probability that a compromised dependency could cause critical damage, allowing proportional reduction of untrusted dependencies based on each subsystem's risk level.

Labs should begin this transformation now by architecting systems that separate components with weight access from those without, enabling different dependency requirements for each subsystem. In parallel, they should eliminate existing dependencies in critical subsystems. Key areas requiring attention include operating systems, ML frameworks, and containerization/orchestration tools [22], [23]. The earlier labs establish these boundaries and reduce dependencies, the smoother their SL5 transition will be—early investment will compound to enable faster adaptation when needed.

Cost-Benefit

1. **Costs:** Engineering effort for both architectural separation and dependency reduction, plus operational overhead from maintaining separate subsystems with different dependency sets. Engineers on critical components lose access to many external packages, requiring custom implementations.
2. **Benefits:** Enables risk-proportionate attack surface reduction by allowing weight-accessing systems to run with minimal dependencies while less critical systems retain necessary functionality. Dramatically reduces vulnerability exposure to the most sensitive components without completely sacrificing the productivity benefits of external packages in lower-risk areas.
3. **Alternatives:** Accepting current dependency chains (massive attack surface); attempting reduction without architectural separation (limited effectiveness); or deferring until SL5 transition (more disruptive, might be too late).

Review, prune, refactor, rewrite, or formally verify all external security-critical software

Explanation of Recommendation

We recommend that AI labs apply risk-proportionate hardening techniques to all external software with access to model weights, outputs, or critical infrastructure. This includes both non-AI and AI-assisted techniques such as **vulnerability scanning, feature pruning, security refactoring, language rewriting (e.g., C to Rust), and formal verification**, based on the software's criticality and AI capabilities available at implementation time. Security-critical software includes components with access to model weights, model outputs (which could enable distillation) [24], [25], CI/CD tools that affect these systems, and network access to weight storage. Labs should classify external dependencies by their security properties—trust level, codebase size, test coverage, language safety characteristics, and production criticality—then apply appropriate hardening based on this classification.

Research Reasoning

This tiered approach leverages expected advances in AI-assisted software hardening capabilities while accounting for uncertainties. We anticipate decreasing software volumes at higher security levels in data centers, making stricter interventions feasible for the most critical components. Labs will need to carefully architect their systems to support clean security boundaries between tiers and analyze the security properties of each import. The effectiveness depends on **two key unknowns: the maturity of AI capabilities for tasks like secure language rewriting and formal verification assistance** when needed, and the actual **scope of software requiring these interventions**. Labs should start investing in and differentially accelerating these neglected cyber-defense capabilities.

While some benchmarks exist for certain capabilities, there appear to be **limited well-established evaluations specifically for secure-language rewriting or formal-verification assistance**; recent system/model cards and surveys suggest these capabilities may **not yet be actively optimized** [26]–[31].

Labs that invest now in developing these capabilities will be able to apply stricter processes to more software. Since LLM outputs may not be trustworthy [15], [16], additional controls may be necessary when applying these procedures. See our personnel security document for such controls.

Cost-Benefit

1. **Costs:** Engineering time for hardening processes, compute resources for AI-assisted analysis, and the risk of introducing bugs during rewrites that cause system malfunctions.
2. **Benefits:** Optimizes the security-functionality trade-off by applying resource-intensive interventions like formal verification only to the most critical components while using lighter-weight processes like pruning for less sensitive software. Enables use of external dependencies while mitigating sophisticated backdoors and vulnerabilities that would otherwise remain undetected.
3. **Alternatives:** Applying only automated vulnerability scanning and manual review (leaves sophisticated backdoors undetected); completely avoiding external dependencies (impractical given the scope of required software); relying solely on sandboxing and isolation (provides defense-in-depth but does not eliminate vulnerabilities); or accepting full codebases as-is (unacceptable risk for nation-state threats).

Review and audit the hardware supply chain for security-critical components using a trusted, diverse supplier base

Explanation of Recommendation

AI labs should review and regularly audit their hardware suppliers for security-critical components, while maintaining a **diverse supply base of trusted sources for those components to eliminate single points of failure**. The intent is not broad vendor diversity. It is controlled by diversity within a high-assurance supplier program. For SL5, labs should (1) define which components are security-critical, (2) set a minimum diversity requirement per critical component category (for example, at least two independent trusted sources or supply paths), and (3) limit procurement to a small set of pre-qualified suppliers that can support deep vetting, high transparency, and recurring audits. Chosen suppliers must regularly pass security audits, and in some cases should be assessed against relevant SL5 personnel security controls.

Research Reasoning

Most current training and inference stacks rely on components sourced from an extensive list of vendors, some of which have hard-to-verify provenance or known vulnerabilities (including Intel, AMD, etc.) [32]-[34]. A very broad vendor base increases exposure because it is difficult to maintain deep, continuous visibility into every supplier. At the same time, over-consolidating on a single supplier creates single points of failure and increases the impact of a disruption or compromise. On balance, controlled diversity improves security because it reduces correlated failures and complicates adversary targeting, but only if the diverse sources are deeply trusted and continuously monitored.

Unlike other areas of AI security which are predominantly defense advantaged, supply chain security is arguably offense advantaged, making it a field which differentially benefits from utilizing the strategy of **"security by obscurity"** (i.e., sacrificing the security posture's simplicity for the benefit of obfuscating the posture to the attacker) [49].

DoDI 5200.44 [47] explicitly emphasizes minimizing supply chain risk to ensure uncompromised systems, and it relies on all-source intelligence analysis of suppliers. That depth of vetting is operationally infeasible across a broad, diverse vendor base. Therefore, for SL5 we recommend a **consolidated, high-assurance supply chain model that still preserves diversity for critical components by using a small number of trusted suppliers per component category**, similar in spirit to a "Trusted Supplier" approach. As procurement decisions are made for SL5 data centers and endpoints, prefer components where at least two trusted sources can be sustained (such as switches, NICs, cables, CPUs, and other replaceable infrastructure). Where possible, establish **agreements that improve visibility and auditability**, including **access to key design artifacts** needed to verify delivered hardware. Combine this with recurring and **randomized audits designed to detect sophisticated compromise**, including targeted deep inspections and sampled destructive evaluation when warranted. This approach is consistent with SP 800-161 Rev. 1 guidance [48] on supply base diversification, which emphasizes diversification as a means to eliminate single points of failure for critical components. SP 800-161 explicitly couples diversification with strong supplier due diligence, upstream dependency analysis, and continuous monitoring, recognizing that unmanaged diversity can increase risk by overwhelming an organization's ability to perform deep vetting

Cost-Benefit

1. **Costs:** Higher qualification and audit overhead, smaller pool of eligible suppliers, potential price increases, added engineering work to support two or more approved parts, and trusted suppliers may become more attractive targets.
2. **Benefits:** Raises adversary cost by requiring compromise across multiple trusted supply paths instead of one, minimizes supply chain risk while avoiding single points of failure, increases resilience to disruption, improves detection rates through continuous monitoring and audits.
3. **Alternatives:** Broad, open diversification across many vendors (makes all-source vetting and continuous assurance infeasible); strict single-supplier consolidation (creates single points of failure and increases impact, though would also simplify the implementation and enforcement of rigorous security controls); rely solely on post-delivery inspection without deep supplier vetting (misses sophisticated embedded compromises); or attempt complete onshoring of all components (infeasible in the near term given current manufacturing capabilities).

Develop and deploy adversarially robust systems to verify data integrity

Explanation of Recommendation

We recommend that AI labs develop and then deploy adversarially robust detection systems to **screen all textual content entering the data center**—including training data, inference inputs, and code undergoing LLM-based hardening—for **poisoning attempts, jailbreaks, and other malicious content**. This control requires screening of all text that could influence SL5 models or data center operations. Detection systems must identify backdoor attacks in training corpora, jailbreak attempts in inference data, and malicious patterns in code being reviewed or rewritten by LLMs. For code specifically, attackers could craft inputs that jailbreak the reviewing LLM to ignore vulnerabilities, insert backdoors, or introduce subtle sabotage. The **detection systems themselves must be hardened against adversarial attacks**, as sophisticated actors may craft inputs designed to bypass screening while compromising target systems.

Research Reasoning

Adversarial robustness remains an unsolved problem [17]. While production systems like Anthropic's Constitutional Classifiers [40] and OpenAI's safety systems for ChatGPT Agent [41] demonstrate initial capabilities, comprehensive detection for data poisoning does not yet exist [35], [36], [42], [43]. Nation-state actors could embed sophisticated backdoors that activate under specific conditions or craft inputs that appear benign while triggering unintended behaviors. **The scale challenge is acute**—SL5 training will require vast text corpora where **manual review is infeasible** [44]. Automated systems must maintain high detection rates while managing false positives. More research is needed to have trust in datasets that will be used for SL5. **Labs investing now in detection research will be better positioned when SL5 capabilities emerge**.

Cost-Benefit

1. **Costs:** Computational overhead for screening (depending on implementation, potentially approaching a meaningful fraction of training costs), delays from false positives, and substantial R&D investment. Detection research timelines as well as feasibility of reaching a high accuracy remain uncertain.
2. **Benefits:** Prevents sophisticated data poisoning attacks that could compromise model behavior, protects against jailbreak attempts that could bypass safety measures, and provides defense against malicious code injections during LLM-assisted hardening processes.
3. **Alternatives:** Accept poisoning risk while relying on other defenses (leaves models vulnerable to sophisticated backdoors); radically reduce external data (severely limits training data diversity and model capabilities); manual review (infeasible at the scale required for SL5 training); or limit to old data from before ChatGPT era (poisoning attacks likely weren't happening yet, but significantly restricts available training data).

Continuously red team all supply chain processes

Explanation of Recommendation

AI labs should implement **automated systems that continuously inject benign adversarial actions into supply chain processes**. This includes occasionally passing intentionally vulnerable or backdoored code through the import process, poisoned data through screening systems, and software dependencies that should not be approved under the minimization paradigm [37]–[39]. Labs should use LLMs to generate diverse attack patterns and test vectors that simulate both basic security failures and sophisticated attacks. These automated systems should be designed in consultation with nation-state-level whitehat attackers to ensure appropriate levels of attack vectors are reflected in this process.

Research Reasoning

Unlike traditional red teaming which provides point-in-time assessments, continuous adversarial injection ensures constant readiness whilst generating metrics on detection effectiveness between formal red team exercises. This approach complements traditional red teaming by serving dual purposes: testing processes against basic attacks that could slip through due to human error or oversight, while also simulating sophisticated attacks that could compromise the supply chain. Critical to implementation is maintaining clear distinction between planned injections and real attacks to prevent adversaries from hiding actual compromise among simulated events.

Cost-Benefit

1. **Costs:** Engineering effort to build automated injection systems and operational overhead from investigating benign alerts, with risk of alert fatigue if poorly calibrated.
2. **Benefits:** Provides continuous validation of security processes between traditional red team exercises, generates metrics on detection effectiveness, and maintains constant readiness against both simple oversights and sophisticated attacks.
3. **Alternatives:** Relying solely on periodic red team exercises (leaves long untested periods); purely reactive monitoring (first failure could be catastrophic); or using only external red teams without continuous testing (expensive and infrequent).

Bibliography

[1] Cybersecurity and Infrastructure Security Agency (CISA), "A Practical Guide to Supply Chain Compromises," 2025. https://www.cisa.gov/resources-tools/resources/practical-guide-supply-chain-compromises

[2] MITRE, "CVE-2024-3094," CVE Record, 2024. https://www.cve.org/CVERecord?id=CVE-2024-3094

[3] Red Hat, "Xz Backdoor Explained & Analysis (CVE-2024-3094)," 2024. https://www.redhat.com/en/blog/xz-backdoor-explained-and-analysis-cve-2024-3094

[4] Electronic Frontier Foundation, "20131230-Appelbaum—NSA ANT Catalog," 2013. https://www.eff.org/document/20131230-appelbaum-nsa-ant-catalog

[5] Kaspersky, "A virus in HDD firmware is real, what's next?," Feb. 2015. https://www.kaspersky.com/blog/equation-hdd-malware/7623/

[6] NIST, SP 800-160, Vol. 1 Rev. 1: Engineering Trustworthy Secure Systems, 2022. https://csrc.nist.gov/pubs/sp/800/160/v1/r1/final

[7] NIST Special Publication (SP) 800-53 Rev. 5.2.0, National Institute of Standards and Technology, Gaithersburg, MD, Nov. 2023. [Online]. Available: https://csrc.nist.gov/projects/cprt/catalog#/cprt/framework/version/SP_800_53_5_2_0/home

[8] lowRISC & partners, "OpenTitan®: Open source silicon root of trust," 2025. https://opentitan.org/

[9] NIST, SP 800-193: Platform Firmware Resiliency Guidelines, 2018. https://csrc.nist.gov/pubs/sp/800/193/final

[10] Confidential Computing Consortium, A Technical Analysis of Confidential Computing, v1.3, 2023. Available: https://confidentialcomputing.io/wp-content/uploads/sites/10/2023/03/CCC-A-Technical-Analysis-of-Confidential-Computing-v1.3_unlocked.pdf

[11] NVIDIA, "Confidential Compute on NVIDIA Hopper H100," Whitepaper, 2023. Available: https://images.nvidia.com/aem-dam/en-zz/Solutions/data-center/HCC-Whitepaper-v1.0.pdf

[12] AMD, "SEV-SNP: Strengthening VM Isolation with Integrity Protection and More," Whitepaper, 2020. https://www.amd.com/en/resources/amd-secure-encrypted-virtualization.html

[13] Intel, "Intel® Trust Domain Extensions (Intel® TDX): Architectural Overview," Whitepaper, 2024. https://www.intel.com/content/www/us/en/content-details/773875/intel-trust-domain-extensions-intel-tdx.html

[14] NIST, SP 800-161 Rev. 1 (with updates through 2024): Cybersecurity Supply Chain Risk Management Practices, 2022. https://csrc.nist.gov/pubs/sp/800/161/r1/upd1/final

[15] OWASP Foundation, "LLM01:2025 Prompt Injection," OWASP GenAI Security Project, 2025. https://genai.owasp.org/llmrisk/llm012025-prompt-injection/

[16] E. Hubinger et al., "Sleeper Agents: Training Deceptive LLMs that Persist Through Safety Training," arXiv:2401.05566, 2024. https://arxiv.org/abs/2401.05566

[17] A. Vassilev et al., "Adversarial Machine Learning: A Taxonomy and Terminology of Attacks and Mitigations," NIST AI 100-2e2025, Mar. 2025, doi:10.6028/NIST.AI.100-2e2025. https://csrc.nist.gov/pubs/ai/100/2/e2025/final

[18] OWASP Foundation, "LLM03:2025 Supply Chain," OWASP GenAI Security Project, 2025. https://genai.owasp.org/llmrisk/llm032025-supply-chain/

[19] S. Rose, O. Borchert, S. Mitchell, and S. Connelly, "Zero Trust Architecture," NIST SP 800-207, Aug. 2020. https://csrc.nist.gov/pubs/sp/800/207/final

[20] Google Cloud, "How Google protects its production services," Google Cloud, Jun. 2024. [Online]. Available: https://cloud.google.com/docs/security/production-services-protection

[21] Cloudflare, "Seat management," Cloudflare Zero Trust docs. [Online]. Available: https://developers.cloudflare.com/cloudflare-one/identity/users/seat-management/

[22] M. Souppaya, K. Scarfone, and D. Dodson, "Secure Software Development Framework (SSDF) Version 1.1," NIST SP 800-218, Feb. 2022. https://csrc.nist.gov/pubs/sp/800/218/final

[23] OpenSSF, "Supply-chain Levels for Software Artifacts (SLSA) v1.0," 2024. https://slsa.dev/spec/v1.0

[24] G. Hinton, O. Vinyals, and J. Dean, "Distilling the Knowledge in a Neural Network," arXiv:1503.02531, Mar. 2015. https://arxiv.org/abs/1503.02531

[25] F. Tramèr, F. Zhang, A. Juels, M. K. Reiter, and T. Ristenpart, "Stealing Machine Learning Models via Prediction APIs," in Proc. USENIX Security, 2016. https://www.usenix.org/conference/usenixsecurity16/technical-sessions/presentation/tramer

[26] OpenAI, "GPT-5 System Card," Aug. 2025. https://openai.com/index/gpt-5-system-card/

[27] Anthropic, "Claude 4 System Card," 2025. Available: https://www-cdn.anthropic.com/4263b940cabb546aa0e3283f35b686f4f3b2ff47.pdf

[28] Google DeepMind, "Gemini 2.5: Technical Report," 2025. Available: https://storage.googleapis.com/deepmind-media/gemini/gemini_v2_5_report.pdf

[29] xAI, "Grok-4 Model Card," Aug. 2025. Available: https://data.x.ai/2025-08-20-grok-4-model-card.pdf

[30] M. Mohammadi et al., "Evaluation and Benchmarking of LLM Agents: A Survey," arXiv:2507.21504, 2025. https://arxiv.org/abs/2507.21504

[31] S. M. Xie et al., "CLEVER: A Curated Benchmark for Formally Verified Code Generation," arXiv:2505.13938, 2025. https://arxiv.org/abs/2505.13938

[32] Microsoft, "KB5029778: How to manage the vulnerability associated with CVE-2022-40982," 2023. https://support.microsoft.com/en-us/topic/kb5029778-how-to-manage-the-vulnerability-associated-with-cve-2022-40982-d461157c-0411-4a91-9fc5-9b29e0fe2782

[33] MITRE, "CVE-2022-40982," CVE Record, 2023. https://www.cve.org/CVERecord?id=CVE-2022-40982

[34] The Hacker News, "New Research Reveals Spectre Vulnerabilities Resurface," Oct. 2024. https://thehackernews.com/2024/10/new-research-reveals-spectre.html

[35] X. Zhang et al., "PoisonBench: Assessing Large Language Model Vulnerability to Data Poisoning," arXiv:2410.08811, 2024. https://arxiv.org/abs/2410.08811

[36] H. Li et al., "Data Poisoning in Deep Learning: A Survey," arXiv:2503.22759, 2025. https://arxiv.org/abs/2503.22759

[37] K. Shortridge and A. Rinehart, Security Chaos Engineering: Sustaining Resilience in Software and Systems, O'Reilly, 2023. https://www.oreilly.com/library/view/security-chaos-engineering/9781098113810/

[38] MITRE, "Caldera™: A Scalable, Automated Adversary Emulation Platform," 2025. https://caldera.mitre.org/

[39] Netflix, "Chaos Monkey," GitHub repository, 2012–2025. https://github.com/Netflix/chaosmonkey

[40] Anthropic, "Constitutional Classifiers," Feb. 2025. https://www.anthropic.com/news/constitutional-classifiers

[41] OpenAI, "Introducing ChatGPT Agent," Jul. 17, 2025. https://openai.com/index/introducing-chatgpt-agent/

[42] N. Carlini, M. Jagielski, C. A. Choquette-Choo, D. Paleka, W. Pearce, H. Anderson, A. Terzis, K. Thomas, and F. Tramèr, "Poisoning Web-Scale Training Datasets is Practical," in Proc. 2024 IEEE Symposium on Security and Privacy (SP), 2024, pp. 407–425. doi: 10.1109/SP54263.2024.00179. https://doi.org/10.1109/SP54263.2024.00179

[43] D. A. Alber et al., "Medical large language models are vulnerable to data-poisoning attacks," Nature Medicine, vol. 31, pp. 618–626, 2025. doi: 10.1038/s41591-024-03445-1. https://doi.org/10.1038/s41591-024-03445-1

[44] P. Villalobos et al., "Will we run out of data? Limits of LLM scaling based on human-generated data," arXiv:2211.04325v2, 2024. https://arxiv.org/html/2211.04325v2

[45] J. Betley, D. Tan, N. Warncke, A. Sztyber-Betley, X. Bao, M. Soto, N. Labenz, and O. Evans, “Emergent Misalignment: Narrow finetuning can produce broadly misaligned LLMs,” arXiv preprint arXiv:2502.17424, ver. 6, May 12, 2025. [Online]. Available: https://arxiv.org/abs/2502.17424

[46] Palisade Research, “Misalignment Bounty Submissions Dataset,” Hugging Face, 2025. [Online]. Available: https://huggingface.co/datasets/palisaderesearch/Misalignment-Bounty-Submissions

[47] U.S. Department of Defense, "Protection of Mission Critical Functions to Achieve Trusted Systems and Networks," DoD Instruction 5200.44, Feb. 16, 2024. [Online]. Available: https://www.esd.whs.mil/Portals/54/Documents/DD/issuances/dodi/520044p.pdf

[48] J. Boyens, A. Smith, N. Bartol, K. Winkler, A. Holbrook, and M. Fallon, “Cybersecurity Supply Chain Risk Management Practices for Systems and Organizations,” NIST Special Publication 800-161 Revision 1 Update 1 (includes updates as of Nov. 1, 2024), National Institute of Standards and Technology (NIST), Gaithersburg, MD, USA, May 2022. doi: 10.6028/NIST.SP.800-161r1-upd1. [Online]. Available: https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-161r1-upd1.pdf

[49] J. C. Smith, Effective Security by Obscurity, arXiv:2205.01547 [cs.CR], Apr. 30, 2022. Available: https://arxiv.org/abs/2205.01547

Network Security Overview

Executive Summary

In the field of network security, we are fortunate to have many established solutions to build on, from both industry and the national security ecosystem. However, these solutions come with major trade-offs and will need to be adapted to the unique and exceptional performance requirements of AI workflows. Our recommendations include **strong network perimeter security** to keep attackers out (and AIs in). They also call for **stronger encryption standards in key areas**. A major source of tension is the practical need for resources to be geographically distributed or remotely accessed and the difficulty of securing long-distance connections. Whether long-distance communications can be secured remains uncertain. **Trade-offs exist between trusting long-distance communications and the extent to which operations can be distributed.** Network design needs to **consider the transformative role automated AI R&D will play** in the future, and provide AI agents access to resources needed for running experiments through controlled and limited interfaces. In this report we share our top five of many recommendations for securing the networks enabling frontier AI development from nation-state level attacks.

Top 5 Recommendations

1. Connect secure sites with inline network encryptors
2. Encrypt accelerator interconnect
3. Isolate powerful models on an air-gapped network
4. Maintain separate enclaves for weight-related operations
5. Develop AI-enhanced cross-domain solutions

Connect secure sites with inline network encryptors

Explanation of Recommendation

We recommend labs encrypt all traffic exiting a secure site to travel over a less secure connection using an inline network encryptor. A secure site could be a data center building, a secure area in an office building, or any other space where a high degree of physical security can be established. By contrast, long-distance connections between these may be infeasible to physically secure. Depending on how much confidence is placed in network encryptors, it may be necessary to avoid using these connections for the most sensitive communications, especially those involving weights such as distributed training.

Research Reasoning

By current trends, training a frontier model may require over 5 GW of power by 2029 [1]. For reference, this is almost half the peak demand of all of NYC [2], and more than any power plant in the US except the Grand Coulee Dam [3]. The compute required for a single frontier AI lab may exceed 10 GW [4]. It is unlikely that this much demand can be supplied at a single location, barring an unprecedented effort in power plant construction. Therefore, it is likely SL5 infrastructure will be geographically distributed, requiring connections to be made over significant distances. These connections must be secured.

USG classified networks like SIPRNet and JWICS overcome this problem using inline network encryptors [5]. These high assurance devices encrypt traffic as it leaves a classified enclave and travels over a lower security connection. USG networks and their contractors use NSA Certified Type 1 encryptors, which are not available for normal commercial use [6] and require strict handling requirements [7]. Alternatively, enterprise network encryptors can offer a similar level of security with many of the same features, complying with FIPS 140-3 Level 3 [8]. In our discussions with experts, we were told that properly used, they may be just as good.

We heard claims from at least one expert that while the cryptographic primitives that underlie network encryptors are highly unlikely to have vulnerabilities, there might exist vulnerabilities in the implementation that could be exploited by a highly capable attacker. In this case, it may be possible to **guard against implementation flaws specific to a single model by using multiple, heterogeneous network encryptors from different suppliers in series**. This is consistent with the NSA's "Rule of Two" [9]. Determining the true vulnerability of these systems may require access to classified information; we leave open the possibility there may be no way to securely make long-distance connections. If these connections cannot be fully trusted, labs may wish to make the most **sensitive transfers with physical storage media**, if at all.

Using network encryptors may present some implementation challenges. Both NSA certified and enterprise encryptors currently offer up to 100-400 Gbps of bandwidth [10], [11]. If training needs to be distributed, future distributed training runs may require over a hundred times more bandwidth [12]. Due to slow development and certification cycles, a solution **may need to rely on multiplexing currently available encryptors**. This is possible, but to date has only been done with small numbers of encryptors [10], likely because there has not yet been a need for more. In **current inter-data center connections, each fiber only carries ~400 Gbps regardless of the total bandwidth** [13]. There may be little need for additional multiplexing if each fiber can be handled by one encryptor. It is also possible that other advancements allow efficient distributed training with much less bandwidth [14], or that bandwidth-intensive tasks can be collocated. This would be desirable since bandwidth-intensive tasks usually involve weights directly.

Cost-Benefit

- **Costs:** Standard pricing is not available, but high bandwidth network encryptors could cost well over $100k each [15]. In scenarios where this supports high bandwidth connections between locations, the size of this demand may also strain the current supply. Multiplexing may present additional costs and challenges. **Latency impact is negligible—on the order of ~2 µs, trivial compared to end-to-end latency** [8], [11].
- **Benefits:** Provides the level of security nation-states depend upon for connections made over untrusted network segments, enabling connections to multiple locations, including office buildings. Adds an additional layer of defense against an insider threat sending unencrypted (or decryptable) traffic outside a secure site.
- **Alternative:** Rely on end-to-end encryption for all communications on the network (note that you should have this anyway). This alternative is likely unacceptably vulnerable, especially to insider threats. Alternatively, make the entire network exist in a single building. This creates a power bottleneck and forces your employees to relocate there.

Encrypt accelerator interconnect

Explanation of Recommendation

We recommend labs encrypt communications over AI accelerator inter-chip interconnect. Messages should be **encrypted on the sending accelerator and decrypted on the receiving accelerator**. This likely requires chip designers to include new features in accelerators, which need to be planned in advance to account for long lead times. Some efforts may already be underway to prepare for this, and we encourage **expanding this effort to all relevant AI chips including novel types that may be in use in the years 2027 and onward**.

Research Reasoning

Broadly, weights and values from which weights could be easily derived should never be stored or transmitted in cleartext. While this is the ideal, one area where this is challenging to implement is accelerator interconnect, which transmits weights and weights related values between accelerators with tremendous speed and volume [16]. The additional latency and compute overhead of encrypting these messages before they leave an accelerator could be impractical if not implemented efficiently [17].

Encrypting interconnect may require dedicated hardware on accelerators, which is not yet standard. Accelerators are optimized to perform only certain operations, which do not include operations crucial to encryption (especially stream ciphers) like XOR [18]–[20]. NVIDIA Hopper GPUs do not have dedicated hardware encryption for GPU-GPU communications over NVLink [21]; however, their new Blackwell GPUs do [22]. Trainium does not currently have dedicated encryption hardware for its NeuronLink interconnect [23], nor does TPU [24]. Future accelerators have been rumored to include these features according to experts we talked to and as previously stated, we strongly encourage the expansion of this to all relevant AI chips.

Since there is a significant delay between chip design and availability, it is **necessary for these features to be requested and planned well in advance**.

Given the difficulty of encrypting interconnect, alternative mitigations could be explored. An attacker intercepting interconnect traffic would require physical access to the cables, which can be physically protected.

Currently, these cables benefit from the security of being inside a data center but are not themselves protected. They could be **secured with an additional enclosure, potentially including tamper-proof or tamper-evident features**.

Cost-Benefit

- **Costs:** Including hardware for encryption will increase the cost of accelerator chips, but once the chip makers decide to include it, that cost becomes built-in. For overhead, NVIDIA claims their solution offers "nearly identical throughput" [22].
- **Benefits:** Interconnect no longer carries sensitive cleartext traffic.
- **Alternative:** Continue to send sensitive cleartext traffic over interconnect and instead rely on enhanced physical security, such as tamper-proof or tamper-evident enclosures. This could make maintenance much more difficult since it needs to be somehow distinguished from tampering.

Isolate powerful models on an air-gapped network

Explanation of Recommendation

We recommend that frontier labs train and host frontier models that pose a catastrophic risk exclusively on an air-gapped network. Serve customer inference with weaker models (or models post-release that clear necessary safety & security thresholds) at SL4.

Research Reasoning

Connections to the internet present a large attack surface, so systems requiring the highest security are often isolated from it [25], [26]. This separation is best enforced by a physical air-gap. Software separation, while convenient, is less reliable. Systems relying on air gapping include USG classified networks like SIPRNet and JWICS as well as critical infrastructure like nuclear power plants or financial systems [27].

Air gapping should never create a false sense of security, and Zero Trust architecture is still desired since breaches are almost inevitable. This is consistent with the strategy networks like SIPRNet have pursued [31].

One may wonder what the point of creating a model is if it is fully isolated from the outside world. Even if no direct connections can be made, a highly capable AI could still provide tremendous value: Groundbreaking research or inventions could be published via the force of secure automated AI R&D. Weaker, more trusted models could be distilled and offered publicly. Future progress in AI Safety and AI security may even make air-gapping unnecessary in the long term. **SL5 is about securing the critical span when models become increasingly capable of automated AI R&D whilst AI alignment has not yet been sufficiently solved. During this critical window, their theft or sabotage poses untenable safety, security and national security risks which must be mitigated with SL5 and other governance and safety mechanisms. SL5 is a powerful tool to buy time to find and build more long-time tenable solutions to the AI alignment and governance problem than currently exist.**

Cost-Benefit

- **Costs:** Air-gapping prevents automatic software updates, powerful models are restricted to internal use only, compute used to serve public inference cannot be used for training runs. Isolated models can still indirectly serve the public.
- **Benefits:** Large reduction in attack surface
- **Alternative:** Forgo air-gapping and focus on software isolation and/or zero trust architecture. Some industry leaders like Google have abandoned relying on perimeter security almost entirely in favor of zero trust architecture [32].

Maintain separate enclaves for weight-related operations

Explanation of Recommendation

We recommend labs restrict weights and weight-related operations for covered models to a separate enclave within the SL5 network where only code that has been signed by a human-reviewed process can execute.

Research Reasoning (see Appendix A as well)

A major vulnerability of an isolated network is the software brought onto it. It must be thoroughly tested and reviewed before being imported [27]. For example, requirements for SIPRNet prevent the installation of “any software and firmware components” lacking a trusted signature [28], [29], and also prevent the execution of unsigned mobile code [28], [30]. Therefore, where possible we should prohibit the execution of unsigned code.

Conversely, software R&D workflows require running unsigned code. At the very least, writing and testing code requires running it, and it cannot be signed before it has been written and tested. Therefore, software development, test, and review require a network with the capability to run unsigned code. However, the software developed to create AI models is also highly sensitive. While not as directly useful as the models themselves, it contains critical knowledge about how to train models, which an adversary with their own compute could recreate.

Therefore an SL5 network must include separate domains where unsigned code is and is not executable. We will refer to these as the “broader SL5 network” and “weight enclave(s)” An interface between these is necessary, but introduces risks and complications.

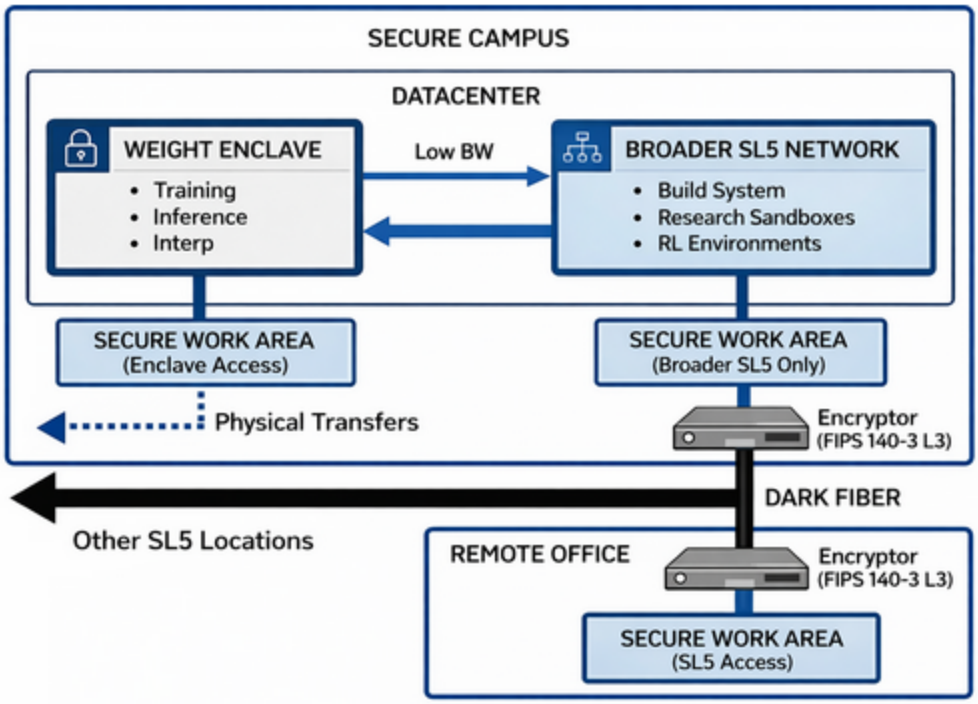


Fig. 1. High-level concept for SL5 Network, see Appendix A for more

Cost-Benefit

- **Costs:** Maintaining separate weight enclaves adds cost and complexity and requires a system to handle communications between them and the broader SL5 network.
- **Benefits:** Creates separation between untrusted code and most sensitive operations. Enables a reduction in the software stack needed in weight storing systems (See Supply Chain recommendations).
- **Alternative:** Rely on sandboxing to run untrusted code.

Develop AI-enhanced cross-domain solutions

Explanation of Recommendation

We recommend labs develop cross-domain solutions (CDS) enhanced with AI monitors to enable limited communication between weight enclaves and the broader SL5 network.

Research Reasoning

AI assisted or automated research workflows will likely involve thousands of models conducting experiments around the clock involving writing and executing code [33], [34]. If these AI models exist within weight enclaves where only vetted and signed code can be run, there must be a cross-domain solution to transfer this code and associated commands to the broader SL5 network where unsigned code can be executed.

Execution of this unsigned code should also occur in a sandbox environment, but these are not free of vulnerabilities [35], including powerful sandbox techniques used by cloud providers [36]. A capable AI may be able to exploit these. Additionally, this channel could be used to exfiltrate or distill the model weights into an environment where unsigned code could operate on them. A cross-domain solution is needed that addresses these concerns.

Cross-domain solutions are used, including in classified national security environments, to enable communications between two otherwise air-gapped security domains [37]. Existing cross-domain transfer solutions rely heavily on labels [37]. Information is associated with a cryptographically bound label that indicates among other things its classification level. The CDS can then apply rule-based functions to these labels to determine if the information can pass [38]. While this approach may be suited to sharing classified documents, it does not translate well to the task of newly written software and commands. In current implementations, labels are created through a tedious manual process [39]. This is not feasible for content newly generated by AIs at scale.

Additionally, the goal of labeling differs. “Classified information” can be analogized to weights and weight-related values which should never be exfiltrated to the broader SL5 network, but the CDS should also reject malicious code and commands. While there may still be a place for labels and rule-based functions, to cover the full scope of the problem likely requires using an AI monitor to detect and reject suspicious files and commands. Relevant ideas from the space of AI control may be applicable [40]–[42]. Ideas in this space rely on weaker, more trusted AI models checking the outputs of more powerful AIs for suspicious activity, and involving human monitors in an efficient and targeted manner. More work should be done to research and develop these techniques.

Other cross-domain solution properties can be achieved with existing solutions. One-way connections can be enforced with data diodes [43], including variations that allow for packet acknowledgements and rate limiting [44].

Combining these features can ensure that cross-domain connections do not enable a high-bandwidth path from a weight enclave to the broader SL5 network, defending against exfiltration of model weights. Bandwidth limiting is already a method being implemented to prevent model exfiltration [45]. Its efficacy is enabled by the large size of models (GPT-4 is believed to be ~3.4 TB [46]) in comparison to the volume of legitimate traffic (1 billion lines of code would be ~50 GB at 50 characters per line, for context all Google services are 2 billion lines [47]). Therefore, total egress can be kept below some safe fraction of model size.

Cost-Benefit

- **Costs:** AI monitors could consume a non-trivial amount of compute. These monitors should primarily be needed for connections leaving a weight enclave, since that is where suspicious AI actions would originate. This would mean these resources are still available for large training runs.
- **Benefits:** Enables AI assisted research and development workflows, while defending against attempts to execute malicious unsigned code or exfiltrate weights.
- **Alternative**: Restrict AI code and action space to what can be defined as safe by a set of explicit rules. This may be very restrictive. Place greater trust in sandboxing implementation.

Bibliography

[1] K. F. Pilz, Y. Mahmood, and L. Heim, “AI’s Power Requirements Under Exponential Growth: Extrapolating AI Data Center Power Demand and Assessing Its Potential Impact on U.S. Competitiveness,” Rand.org, Jan. 28, 2025. https://www.rand.org/pubs/research_reports/RRA3572-1.html

[2] New York Independent System Operator (NYISO), 2023 Load & Capacity Data Report (Gold Book), Table I-3a, p. 27, Apr. 2023. [Online]. Available: https://www.nyiso.com/documents/20142/2226333/2023-Gold-Book-Public.pdf

[3] “Electricity generation, capacity, and sales in the United States - top 10 - U.S. Energy Information Administration (EIA),” www.eia.gov, Oct. 26, 2023. https://www.eia.gov/energyexplained/electricity/electricity-in-the-us-top-10.php

[4] R. Dean, “Compute Forecast — AI 2027,” Ai-2027.com, Apr. 2025. https://ai-2027.com/research/compute-forecast#power-requirements

[5] J. Loyall, K. Rohloff, P. Pal, and M. Atighetchi, “A Survey of Security Concepts for Common Operating Environments,” IEEE, Mar. 2011, doi: https://doi.org/10.1109/isorcw.2011.31.

[6] “CSfC vs Type 1 Encryption: An Overview - Crystal Group,” Crystal Group, May 31, 2024. https://www.crystalrugged.com/knowledge/csfc-vs-type-1-encryption/

[7] “NSA Type 1 Products vs. Commercial Solutions for Classified (CSfC),” AFCEA International, May 04, 2020. https://www.afcea.org/signal-media/cyber/sponsored-nsa-type-1-products-vs-commercial-solutions-classified-csfc

[8] “Thales CN9120 Network Encryptor,” Thales, Dec. 2024. Available: https://www.thalestct.com/wp-content/uploads/2022/09/cn9120-network-encryptor-PB-12-11-24.pdf

[9] “Commercial Solutions for Classified Program - NSA/CSS,” nsa.gov, 2015. https://web.archive.org/web/20151225183650/https://www.nsa.gov/ia/programs/csfc_program/#dar

[10] “TACLANE E-Series High Speed Encryption Solutions - General Dynamics Mission Systems,” Gdmissionsystems.com, 2025. https://gdmissionsystems.com/products/encryption/taclane-network-encryption/taclane-e-series-high-speed-encryptors

[11] “400G Ethernet Data Encryptor,” Secturion.com, 2024. https://www.secturion.com/products/data-in-transit/darklink-400g-ede/

[12] D. Patel, “Multi-Datacenter Training: OpenAI’s Ambitious Plan To Beat Google’s Infrastructure,” SemiAnalysis, Sep. 04, 2024. https://semianalysis.com/2024/09/04/multi-datacenter-training-openais/

[13] "Optical Transceiver Technology Trends of Data Center in 2022," FiberMall, 2022. [Online]. Available: https://www.fibermall.com/blog/optical-transceiver-technology-trends-of-data-center-in-2022.htm.

[14] A. Douillard et al., “DiLoCo: Distributed Low-Communication Training of Language Models,” arXiv.org, 2023. https://arxiv.org/abs/2311.08105

[15] “Defense-Wide Justification Book Volume 1 of 2,” Defense Information Systems Agency, Feb. 2020. Available: https://comptroller.defense.gov/Portals/45/Documents/defbudget/fy2021/budget_justification/pdfs/02_Procurement/DISA_PB2021.pdf

[16] “NVLink High-Speed GPU Interconnect | NVIDIA Quadro,” Nvidia.com, 2025. https://www.nvidia.com/en-us/products/workstations/nvlink-bridges/

[17] Y. Deng et al., "Characterization of GPU TEE Overheads in Distributed Data Parallel ML Training," arXiv:2501.11771, Jan. 2025. [Online]. Available: https://arxiv.org/abs/2501.11771.

[18] “How does the XOR operation function in the encryption and decryption processes of a stream cipher?,” European IT Certification Academy, Jun. 12, 2024. https://eitca.org/cybersecurity/eitc-is-ccf-classical-cryptography-fundamentals/stream-ciphers/stream-ciphers-random-numbers-and-the-one-time-pad/examination-review-stream-ciphers-random-numbers-and-the-one-time-pad/how-does-the-xor-operation-function-in-the-encryption-and-decryption-processes-of-a-stream-cipher/

[19] “Available TensorFlow Ops,” Google Cloud, 2025. https://cloud.google.com/tpu/docs/tensorflow-ops

[20] “Custom Operators API Reference Guide [Beta] — AWS Neuron Documentation,” Readthedocs-hosted.com, 2023. https://awsdocs-neuron.readthedocs-hosted.com/en/latest/neuron-customops/api-reference-guide/custom-ops-ref-guide.html#custom-ops-api-ref-guide

[21] “NVIDIA Trusted Computing Solutions,” NVIDIA, Mar. 2025. Available: https://docs.nvidia.com/570TRD1-trusted-computing-solutions-release-notes.pdf

[22] “NVIDIA Blackwell Architecture Technical Overview,” NVIDIA, 2024. https://resources.nvidia.com/en-us-blackwell-architecture?ncid=no-ncid

[23] “Trainium Architecture — AWS Neuron Documentation,” Readthedocs-hosted.com, 2025. https://awsdocs-neuron.readthedocs-hosted.com/en/latest/general/arch/neuron-hardware/trainium.html

[24] A. Vahdat, “Ironwood: The first Google TPU for the age of inference,” Google, Apr. 09, 2025. https://blog.google/products/google-cloud/ironwood-tpu-age-of-inference/

[25] J. Park, J. Yoo, J. Yu, J. Lee, and J. Song, “A Survey on Air-Gap Attacks: Fundamentals, Transport Means, Attack Scenarios and Challenges,” Sensors, vol. 23, no. 6, p. 3215, Jan. 2023, doi: https://doi.org/10.3390/s23063215.

[26] S. Nevo, D. Lahav, A. Karpur, Y. Bar-On, H. A. Bradley, and J. Alstott, “Securing AI Model Weights: Preventing Theft and Misuse of Frontier Models,” www.rand.org, May 30, 2024. https://www.rand.org/pubs/research_reports/RRA2849-1.html

[27] IBM, “Air gap,” Ibm.com, Oct. 10, 2024. https://www.ibm.com/think/topics/air-gap

[28] “Categorization and Control Selection for National Security Systems,” Committee on National Security Systems, Jun. 2022. Available: https://rmf.org/wp-content/uploads/2022/10/CNSSI_1253_2022.pdf

[29] “Security and Privacy Controls for Information Systems and Organizations | CM-14,” Nist.gov, Nov. 07, 2023. https://csrc.nist.gov/projects/cprt/catalog#/cprt/framework/version/SP_800_53_5_1_1/home?element=CM-14

[30] “Security and Privacy Controls for Information Systems and Organizations | SC-18,” Nist.gov, Nov. 07, 2023. https://csrc.nist.gov/projects/cprt/catalog#/cprt/framework/version/SP_800_53_5_1_1/home?element=SC-18

[31] K. DelBene, M. Medin, R. Murray, and S. Moore, “Zero Trust Architecture (ZTA) Recommendations,” DEFENSE INNOVATION BOARD, Oct. 2019. Available: https://innovation.defense.gov/Portals/63/Templates/Updated%20Meeting%20Documents/ZTA%20Recommendations_CLEARED.pdf

[32] R. Ward and B. Beyer, “BeyondCorp: A New Approach to Enterprise Security | USENIX,” www.usenix.org, Dec. 2014. https://www.usenix.org/publications/login/dec14/ward

[33] D. Kokotajlo, S. Alexander, T. Larsen, E. Lifland, and R. Dean, “AI 2027,” Ai-2027.com, Apr. 03, 2025. https://ai-2027.com/

[34] D. Owen, “Interviewing AI researchers on automation of AI R&D,” Epoch AI, Aug. 27, 2024. https://epoch.ai/blog/interviewing-ai-researchers-on-automation-of-ai-rnd

[35] “Known Exploited Vulnerabilities Catalog | CISA,” Cybersecurity and Infrastructure Security Agency CISA, 2024. https://www.cisa.gov/known-exploited-vulnerabilities-catalog?search_api_fulltext=sandbox

[36] F. Wilhelm, “Project Zero: An EPYC escape: Case-study of a KVM breakout,” Project Zero, Jun. 29, 2021. https://googleprojectzero.blogspot.com/2021/06/an-epyc-escape-case-study-of-kvm.html

[37] B. Adam, “Cross Domain Solutions Overview,” Under Secretary of Defense for Research and Engineering, Feb. 2023. Available: https://www.dau.edu/sites/default/files/Migrate/EventAttachments/838/Slides_DAU%20CDS%20Webinar_Adam_9Feb2023.pdf

[38] “Isode Approach to Data Centric Security using NATO Confidentiality Labels - Isode,” Isode, Jul. 24, 2025. https://www.isode.com/whitepaper/isode-approach-to-data-centric-security-using-nato-confidentiality-labels/

[39] H. Hammer, K. Kongsgard, A. Bai, A. Yazidi, N. Nordbotten, and P. Engelstad, “Automatic Security Classification by Machine Learning for cross-domain Information Exchange,” Military Communications Conference, Oct. 2015, doi: https://doi.org/10.1109/milcom.2015.7357672.

[40] A. Bhatt et al., “Ctrl-Z: Controlling AI Agents via Resampling,” arXiv.org, 2025. https://arxiv.org/abs/2504.10374

[41] R. Greenblatt et al., "AI Control: Improving Safety Despite Intentional Subversion," arXiv:2312.06942, Dec. 2023. [Online]. Available: https://arxiv.org/abs/2312.06942.

[42] Y. Bai et al., "Constitutional AI: Harmlessness from AI Feedback," arXiv:2212.08073, Dec. 2022. [Online]. Available: https://arxiv.org/abs/2212.08073

[43] “Learn About Data Diodes : Owl Cyber Defense,” Owlcyberdefense.com, 2019. https://owlcyberdefense.com/learn-about-data-diodes/

[44] “XML Guard - Isode,” Isode, Jul. 19, 2024. https://www.isode.com/product/xml-guard/

[45] “Activating AI Safety Level 3 Protections,” Anthropic.com, 2025. https://www.anthropic.com/news/activating-asl3-protections

[46] M. Schreiner, “GPT-4 architecture, datasets, costs and more leaked,” *THE DECODER*, Jul. 11, 2023. https://the-decoder.com/gpt-4-architecture-datasets-costs-and-more-leaked/

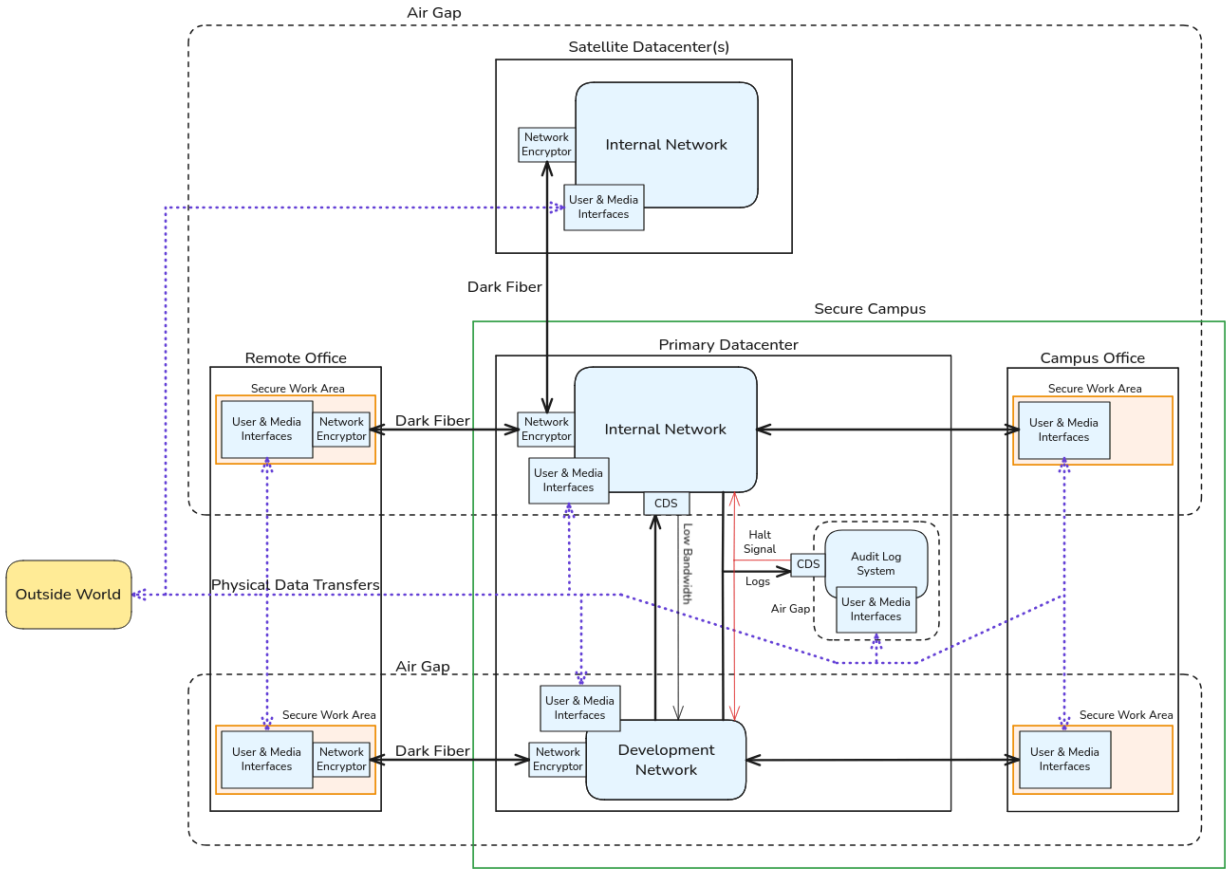
[47] C. Metz, “Google Is 2 Billion Lines of Code—And It’s All in One Place,” Wired, Sep. 16, 2015. https://www.wired.com/2015/09/google-2-billion-lines-codeand-one-place/

[48] J. Harris and E. Harris, “America’s Superintelligence Project,” Gladstone AI, Apr. 2025. Available: https://superintelligence.gladstone.ai/assets/America's%20Superintelligence%20Project%20[Redacted].pdf

Appendix A

These diagrams are not part of the recommendations, but are included to demonstrate what an SL5 network might look like.

Scenario 1: Trusted Long-Distance Connections



Aspects of this diagram not in recommendations:

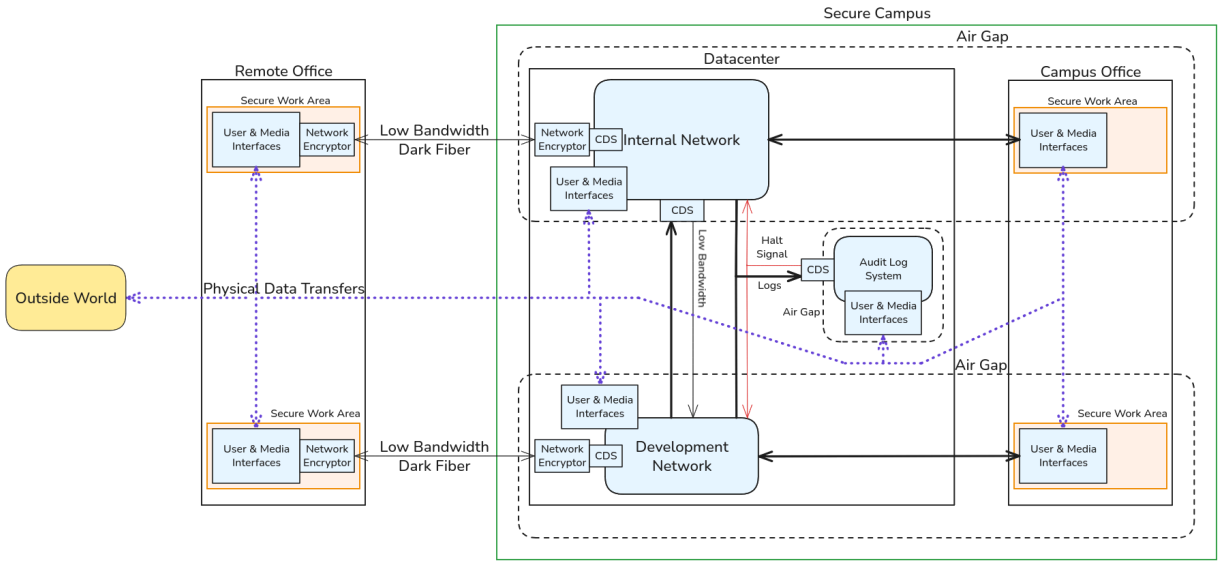
- An audit log system stores logs from both the Development and Internal Networks and has the capability to halt processes in either
- Connections outside physically secured areas are made using dark fiber (note that while useful, dark fiber is vulnerable to highly capable attackers [48])
- Physical transfers allow data to be exchanged with the outside world and within the system

Where do things happen on the network?

- If it requires high bandwidth access to models, it occurs on Internal Network
- If it requires execution of unsigned code, it occurs on the Development Network
- Open question: What workflows might require both, how could these be handled?
- Open question: What workflows might require access to frontier model weights?

- If it requires internet access it occurs on a non-SL5 network, this is out of scope, but parts of office buildings outside the secure work areas could have access to this network to facilitate physical transfer

Scenario 2: No Trusted Long-Distance Connections



Like the previous scenario, except air-gaps are not considered to extend outside physically secured enclaves, and long-distance connections are limited to low bandwidth.

It is also possible to imagine additional campuses connected only by low bandwidth connections and relying otherwise on physical transfers. Some tasks may be highly suited to distribution under such constraints, such as a pretraining run or synthetic data generation.

Machine Security

Overview

Executive Summary

Capable adversaries have proven time and again they can do the seemingly impossible, often by exploiting vulnerabilities easily overlooked in highly complex systems or by invalidating trusted assumptions. This is especially clear in Machine Security, with examples including Spectre/Meltdown and Bullrun [1]–[4]. Most of security is not about outsmarting the adversary, but minimizing attack vectors and simplifying systems [5]–[8].

The scope of Machine Security is the trust granted by devices to higher-level logic. Due to the specific use-case we are addressing, there are key points we can leverage into novel yet accessible solutions, deferring trust from complex to simple systems and incorporating existing technologies into process design. **We highlight five priority recommendations below**, including several existing industry trends we believe should be accelerated and adopted for SL5.

Top 5 Recommendations

1. Push for AI Accelerators to have stronger security features.
2. Employ verified/measured boot on devices with privileged access in a way trusted individuals can reliably verify.
3. Use simple devices to defer authorization away from complex systems like personal computers.
4. Push for tamper-proof and tamper-evident enclosures that can envelop an entire sensitive scope.
5. Design processes with planned adversarial injections.

Push for AI Accelerators to have stronger security features

Explanation of Recommendation

Labs should push chip designers to include critical security features in the next generation of AI accelerators. Requested features should include an integrated root-of-trust, support for interconnect encryption, and comprehensive tamper-proofing. Given lengthy development cycles, these requests need to be made well before expected availability [9].

Research Reasoning

AI accelerators have historically lacked critical security features, leaving model weights and sensitive data vulnerable to extraction. One example is earlier generations of accelerators (e.g., TPU v3 and v4) that typically lack native link-layer encryption for ICI. For instance, TPU v4 relies on Optical Circuit Switches (OCS) to create "air gapped network isolation" between customers rather than encrypting the data on the interconnects [26]. Consequently, model weights and other sensitive data are transmitted between accelerators in plaintext. These could potentially be intercepted directly from the cables in data centers without any need to interact with the chip itself. The data exists unencrypted not only in the cables, but in the networking components on the chips. This weakness undermines existing security features on the chips. See more about this in the network security memo.

The most important security feature needed on accelerators is an integrated root of trust that enables measured boot capabilities. This root of trust must be the first component to activate at power-on and should perform a measured boot that is attested from a protected key. The tamper-proofing standards should likely meet FIPS 140-3 Level 4 requirements, though currently existing products are only FIPS 140-2 validated, which will expire in September 2026 [11], [12].

An unavoidable challenge is that model weights and sensitive data must exist unencrypted inside the actual processing units during computation [13], [14]. This means that even with a secure root of trust, the compute cores themselves become attractive targets for adversaries. Therefore, comprehensive tamper-proofing must extend beyond just the root of trust to cover all contexts where sensitive data exists in plaintext form. Without this holistic approach to hardware security, adversaries could potentially bypass cryptographic protections by targeting the physical components where data must be processed in its unencrypted state.

By implementing these features at the hardware level, organizations can establish a foundational security layer that protects against both physical and logical attacks on AI infrastructure [10].

Cost-Benefit

1. **Costs:** Increased chip design complexity and development time; Higher manufacturing costs due to additional security modules; Potential performance overhead from encryption/decryption operations; Committing to only decrypting model weights at a low level may block some higher-level optimizations.
2. **Benefits:** Protection against physical cable-tapping attacks; Cryptographic verification of hardware integrity; This is crucial for trusting other mechanisms like code signing; Foundation for building higher-level security architectures; Competitive advantage as security becomes a key differentiator.
3. **Alternatives:** Rely on host-side TEEs/DPUs to encrypt interconnect traffic and gate access, combined with strict key management and physical controls, instead of adding new accelerator features.

Employ verified/measured boot on all devices with privileged access

Explanation of Recommendation

Labs should implement cryptographically verified boot processes on every device with access to sensitive information, including AI accelerators, authorization servers, and employee workstations. A cryptographically robust and tamper-proof attestation process should be included that prevent spoofing verification results. For architectural reference, see [16]–[18].

Research Reasoning

Many devices across the infrastructure stack have privileged access to sensitive information including model weights, algorithmic secrets, and other critical data. These devices exist at different network locations, and many are responsible for authorization and authentication decisions. The distributed nature of these systems creates multiple potential entry points that adversaries could exploit if any single device is compromised.

Consider an authorization server where employee devices connect to receive authentication tokens or keys for accessing model weights (directly or indirectly): This server requires measured boot capabilities implemented in a tested way, with cryptographically solid attestation [15], [19], [20]. Without proper verification, an adversary could potentially modify the authorization server's software to grant themselves access or to log legitimate credentials for later use.

The attestation mechanism itself must be tamper-proof to prevent adversaries who gain physical access from copying private keys and creating their own falsely "verified" attestations. This multi-layered approach to boot verification creates defense in depth. Even if an adversary compromises one aspect of the system, they cannot easily bypass the entire verification chain. The measured boot process should create an immutable record of exactly what software is running, allowing security teams to detect any unauthorized modifications before sensitive operations begin.

Cost-Benefit

1. **Costs:** Implementation complexity across diverse device types; Performance impact during boot sequences; Need for secure key management infrastructure; Training requirements for IT staff; Potential compatibility issues with legacy systems; Ongoing maintenance of attestation servers.
2. **Benefits:** Detection of rootkits and firmware-level malware; Prevention of unauthorized software modifications; Centralized visibility into device integrity status; Compliance with zero-trust architecture principles; Reduced insider threat potential; Faster incident response through integrity verification.
3. **Alternatives:** Use golden-image allowlists, signed packages, and frequent integrity scans with EDR/SIEM monitoring as an interim control, accepting residual firmware risk until measured boot with remote attestation is feasible.

Use simple devices to defer authorization away from complex systems

Explanation of Recommendation

We recommend that AI labs ensure critical authorization decisions do not rely solely on complex, general-purpose computers that present large attack surfaces. Instead, labs should deploy dedicated, simple-hardware devices that handle cryptographic signing and user confirmation for sensitive operations. These devices, potentially as simple as a single die with basic display, signing and input capabilities, should create a buffer between the complex computing environment and the final authorization step, ensuring that compromising a workstation alone cannot result in unauthorized access to sensitive systems.

Research Reasoning

The proposal is to use a physical hardware device ideally consisting of a single die with integrated trusted components capable of cryptographic signing, text display, and basic communication with a computer via simple interfaces like serial or USB. While complex systems will inevitably have exploitable flaws, it is plausible that such a device could not be compromised.

By requiring both the computer and a separate simple device for authorization, the system ensures that compromising the computer alone is insufficient to execute authorization-required actions. The simple device displays information to the user, who then accepts or declines via a physical button, after which the device signs the request and returns it. This creates a physical, verifiable action that cannot be simulated by malware on the compromised computer.

This principle extends beyond individual authorization to other sensitive contexts, such as code review stations where the approved code's integrity must be guaranteed. The simplicity of these devices also enables potential hardware verification. If manufactured using appropriate processes rather than cutting-edge nodes like 5nm, the devices could be scanned and verified using techniques such as **infrared imaging** (IR) or **scanning electron microscopy (SEM)**, with the resulting netlists compared to the original design [22], [23]. This level of hardware transparency is practically impossible with complex general-purpose computers but becomes feasible with purpose-built simple devices.

Cost-Benefit

1. **Costs:** Development of custom hardware devices; Manufacturing and distribution costs; Integration with existing authorization workflows; User training for new authorization process; Potential workflow disruption during transition; Physical device management and replacement.
2. **Benefits:** Dramatic reduction in attack surface for critical operations; Physical verification of user intent; Immunity to software-based attacks on workstations; Potential for hardware verification and auditing; Clear separation of concerns in security architecture; Enhanced protection against insider threats; Visible security measure that reinforces security culture.
3. **Alternatives:** Require multi-party approval (e.g., 2-of-3) using standard FIDO2 security keys [21] or HSM-backed approvals on existing workstations, instead of introducing a new dedicated authorization device. This requires in-depth review of each action.

Support tamper-proof and tamper-evident enclosures that can envelop entire sensitive scopes

Explanation of Recommendation

Labs should use tamper-proof enclosures that extend beyond individual components to protect entire operational contexts: from single chips to complete server racks. These physical security measures must meet stringent certification standards and should be scaled appropriately to the scope of the sensitive operations being protected.

Research Reasoning

Security cannot rely solely on cryptographic protections when sensitive data must exist in plaintext during processing. Instead, we can rely on physical tamper-proofing protections. The current state of tamper-proof technology reveals significant limitations. Only four devices have achieved FIPS 140-2 security level 4 certification, all of which are Hardware Security Modules (HSMs), with three manufactured by IBM [25], though many are likely in the pipeline. While HSMs provide a critical security foundation, they represent only one component in a larger system where the actual computational work occurs elsewhere.

If the HSM is not the component performing the main computational work, then the processing units themselves require protection. An adversary who can access the sensitive context outside the HSM could potentially manipulate what gets signed by the HSM, compromising the entire security model. This highlights a fundamental challenge: cryptographic protections are insufficient when attackers can access the physical components where data must be processed in plaintext.

The scope of tamper-proofing may need to extend far beyond individual components. When interconnects lack encryption, protecting a single chip becomes insufficient. The entire rack might need a tamper-proof enclosure. If network protocols like InfiniBand also lack encryption, the theoretical requirement could extend to tamper-proofing entire floors, which while seemingly infeasible, underscores the critical importance of implementing encrypted interconnects in AI accelerators. This escalating scope of physical security requirements creates a strong economic argument for building security features directly into the hardware rather than attempting to retrofit physical protections around insecure components.

Questions of maintainability and resettability of enclosures also have important security implications to be considered for specific solutions separately. Tamper-proof enclosures that need to be opened for maintenance need the ability to be reset, and may require a way to distinguish between legitimate access and tampering. New tamper-proof technologies may be needed to meet these needs.

Cost-Benefit

1. **Costs:** Significant hardware investment for certified enclosures; Custom engineering for different deployment scales; Increased data center space requirements; Complex maintenance procedures requiring security protocols; Higher operational costs for physical security monitoring; Potential cooling and accessibility challenges.
2. **Benefits:** Protection against physical attacks and insider threats; Compliance with highest security certification standards; Defense against side-channel attacks; Visible deterrent to potential adversaries; Complementary layer to cryptographic protections; Preservation of data confidentiality even during processing; Potential for creating secure computation zones.

3. **Alternatives:** Layer physical security (cages, cameras, access logs, tamper seals) and encrypting all links and storage to reduce plaintext exposure, avoiding full rack/floor tamper-proof enclosures.

Design processes with planned adversarial injections

Explanation of Recommendation

Labs should implement automated systems that regularly inject benign but realistic adversarial actions into their processes, creating a constant state of vigilance and ensuring that detection and response mechanisms remain sharp. Labs should leverage AI capabilities to craft adversarial content to more realistically gauge the state of security [24].

Research Reasoning

Security procedures often include tripwires designed to detect malicious activity, but these are rarely triggered in practice. This infrequency creates a dangerous situation where security infrastructure becomes worn down by disuse. When real attacks occur, teams may not know how to respond effectively because they lack practical experience with their response procedures.

The proposed solution extends the concept of red teaming by creating automated, continuous adversarial injections. Unlike traditional red teaming, which provides point-in-time assessments, this approach ensures constant readiness. Just as red teams often receive advantages to test layered defenses, these planned injections can simulate various levels of compromise to ensure that security remains effective even when individual controls fail.

Critical to this approach is maintaining clear distinction between planned injections and real attacks. Organizations must design these systems carefully to prevent adversaries from hiding actual attacks among the planned injections. A practical example involves code review processes where language models could automatically insert malicious code to test whether reviewers catch it. This would quickly identify reviewers who tend to "gloss over" code reviews, allowing for targeted training before real malicious code slips through.

Cost-Benefit

1. **Costs:** Development of injection systems and automation; Computational resources for generating realistic scenarios; Time spent responding to planned injections; Risk of desensitization if not properly managed; Complexity in distinguishing planned vs. real incidents; Ongoing maintenance and scenario updates.
2. **Benefits:** Continuous validation of security controls; Regular practice for incident response teams; Early identification of process weaknesses; Metrics-driven security improvements; Reduced response time during real incidents; Enhanced security awareness across teams; Proactive discovery of detection gaps; Cost-effective alternative to continuous red teaming.
3. **Alternatives:** Run scheduled red-team exercises, tabletop drills, and a bug-bounty program with periodic synthetic log replays to validate detections, rather than continuous adversarial injections in production.

Bibliography

[1] P. Kocher et al., "Spectre Attacks: Exploiting Speculative Execution," 2019. [Online]. Available: https://spectreattack.com/spectre.pdf

[2] M. Lipp et al., "Meltdown," 2018. [Online]. Available: https://meltdownattack.com/meltdown.pdf

[3] G. Greenwald, E. MacAskill, and L. Poitras, "Revealed: how US and UK spy agencies defeat internet privacy and security," The Guardian, Sep. 5, 2013. [Online]. Available: https://www.theguardian.com/world/2013/sep/05/nsa-gchq-encryption-codes-security

[4] N. Perlroth, J. Larson, and S. Shane, "N.S.A. Foils Much Internet Encryption," The New York Times, Sep. 5, 2013. [Online]. Available: https://www.nytimes.com/2013/09/06/us/nsa-foils-much-internet-encryption.html

[5] J. H. Saltzer and M. D. Schroeder, "The Protection of Information in Computer Systems," 1975. [Online]. Available: https://web.mit.edu/Saltzer/www/publications/protection/

[6] NIST, "Security and Privacy Controls for Information Systems and Organizations," SP 800-53 Rev. 5, 2020. [Online]. Available: https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r5.pdf

[7] NIST, "Systems Security Engineering: Considerations for a Multidisciplinary Approach in the Engineering of Trustworthy Secure Systems," SP 800-160 Vol. 1 Rev. 1, 2022. [Online]. Available: https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-160v1r1.pdf

[8] OWASP, "Attack Surface Analysis Cheat Sheet." [Online]. Available: https://cheatsheetseries.owasp.org/cheatsheets/Attack_Surface_Analysis_Cheat_Sheet.html

[9] Semiconductor Industry Association, "Chip Design and R&D," Jan. 2025. [Online]. Available: https://www.semiconductors.org/policies/chip-design/.

[10] V. Ivanov et al., "SAGE: Software-Based Attestation for GPU Execution," in 2023 USENIX Annual Technical Conference (USENIX ATC 23), 2023. [Online]. Available: https://www.usenix.org/conference/atc23/presentation/ivanov

[11] NIST, "FIPS 140-3 Transition Effort," 2024. [Online]. Available: https://csrc.nist.gov/projects/cryptographic-module-validation-program/fips-140-3-transition-effort

[12] NIST, "Security Requirements for Cryptographic Modules," FIPS PUB 140-3, 2019. [Online]. Available: https://nvlpubs.nist.gov/nistpubs/FIPS/NIST.FIPS.140-3.pdf

[13] Confidential Computing Consortium, "Confidential Computing: Hardware-based Trusted Execution for Applications and Data," Whitepaper, 2021. [Online]. Available: https://confidentialcomputing.io/wp-content/uploads/sites/6/2021/03/confidentialcomputingprimer.pdf

[14] T. Hunt et al., "Telekine: Secure Computing with Cloud GPUs," in 17th USENIX Symposium on Networked Systems Design and Implementation (NSDI 20), 2020. [Online]. Available: https://www.usenix.org/conference/nsdi20/presentation/hunt

[15] Microsoft, "Device Health Attestation," Documentation. [Online]. Available: https://learn.microsoft.com/windows/security/operating-system-security/device-health-attestation

[16] IETF, "Remote ATtestation procedureS (RATS) Architecture," RFC 9334, 2023. [Online]. Available: https://www.rfc-editor.org/rfc/rfc9334

[17] Trusted Computing Group, "DICE Attestation Architecture," 2023. [Online]. Available: https://trustedcomputinggroup.org/wp-content/uploads/DICE-Attestation-Architecture-r23-final.pdf

[18] Trusted Computing Group, "TPM 2.0 Library Specification." [Online]. Available: https://trustedcomputinggroup.org/resource/tpm-library-specification/

[19] Trusted Computing Group, "PC Client Platform Firmware Profile Specification." [Online]. Available: https://trustedcomputinggroup.org/resource/pc-client-platform-firmware-profile-specification/

[20] Microsoft, "Windows Defender System Guard: Measured Boot." [Online]. Available: https://learn.microsoft.com/windows/security/information-protection/windows-defender-system-guard/measure-boot

[21] W3C, "Web Authentication: An API for accessing Public Key Credentials Level 2," 2021. [Online]. Available: https://www.w3.org/TR/webauthn-2/

[22] R. Torrance and D. James, "The State-of-the-Art in IC Reverse Engineering," IEEE, 2011. [Online]. Available: https://www.iacr.org/archive/ches2009/57470361/57470361.pdf

[23] Visual 6502, "Visual 6502 Project." [Online]. Available: http://www.visual6502.org/

[24] NIST, "Guide to Test, Training, and Exercise Programs for IT Plans and Capabilities," SP 800-84, 2006. [Online]. Available: https://csrc.nist.gov/publications/detail/sp/800-84/final

[25] NIST, "CMVP Validated Modules Search: IBM, FIPS 140-2, Level 4, Active," 2024. [Online]. Available: https://csrc.nist.gov/projects/cryptographic-module-validation-program/validated-modules/search?SearchMode=Advanced&Vendor=IBM&Standard=140-2&CertificateStatus=Active&ValidationYear=0&OverallLevel=4

[26] N. P. Jouppi et al., "TPU v4: An Optically Reconfigurable Supercomputer for Machine Learning with Hardware Support for Embeddings," arXiv preprint arXiv:2304.01433, p. 4, Apr. 2023.

Physical Security

Overview

Executive Summary

“If a bad actor has unrestricted physical access to your computer, it's not your computer anymore.” - 10 Immutable Laws of Security

No system can be secure without securing the physical devices that implement it. While physical attacks may be more costly (and dangerous) for attackers than other methods, they still pose a critical risk. The importance of physical security is heightened by the realities of imperfect personnel security. It is not enough to deny facility access to outsiders, SL5 must also guard against improper physical access by compromised insiders. Additionally, SL5 must consider physical channels like acoustic or RF noise that might provide a nearby attacker with compromising information without direct physical access. The physical security of current commercial data centers is insufficient to guard against a nation-state threat. Moving from a compliance-based design to a performance-based design that is effective against the defined level of threat is key. We present five recommendations to help close this gap.

Top 5 Recommendations

1. Enforce two-person integrity (TPI) for all maintenance
2. Mandate body-worn cameras with obstruction alarms (prohibited in SCIF-equivalent spaces)
3. Eliminate out-of-facility maintenance
4. Harden side-channel defenses (LED masking, additional noise generators and shielding display cables)
5. Perform pre-installation component X-ray verification

Enforce two-person integrity (TPI) for all maintenance

Explanation of Recommendation

Conduct maintenance and other activities requiring physical access to systems in pairs. Each pair contains an operator responsible for performing tasks and a witness responsible for ensuring integrity. No one is permitted to enter or remain in sensitive areas alone. Assignment of pairs is done in a manner that cannot be controlled or predicted by either member.

Research Reasoning

Enforcing Two-Person Integrity (TPI) greatly mitigates the risk of single-actor insider threat attacks and forces attackers to compromise and coordinate at least two insiders, significantly increasing difficulty and risk of detection.

In high-consequence domains, TPI is used to prevent a lone actor from performing an incorrect or unauthorized action. The U.S. Air Force applies this rigorously to nuclear surety operations [1], where at least two authorized individuals must concur and act together. Procedures explicitly exist to ensure no lone individual can execute critical steps on weapons or certified components. In COMSEC (communications security) programs, TPI is formally defined as a storage/handling system that prohibits individual access to certain material by requiring at least two authorized persons. This is codified in COMSEC doctrine; see the NIST CSRC glossary entry for “two-person integrity” [12]. In the private sector, PCI DSS (Payment Card Industry Data Security Standard) requires split knowledge and dual control for manual clear-text cryptographic key-management operations, an instance of the same principle [13].

Under SL5, TPI should be required for any task that could materially change availability, integrity, confidentiality, or auditability. Examples include: entering white space/MMR/electrical/mechanical rooms to perform work, IDS/ACS shunt or maintenance-mode activation/deactivation, racking/deracking servers, storage sled moves, media insertion/removal, core/leaf/spine cabling changes, BIOS/BMC or HSM actions at a local console, key ceremonies and cryptographic device (HSM/KMS) rekeys, PDU/UPS changes or EPO testing/disable/enable, connecting diagnostic/analysis tools to classified systems, vendor maintenance under escort.

Pairs are separated into operators and witnesses so there is a clear understanding of who is responsible for completing the task and who is responsible for monitoring it. Without this distinction, both may perform a task with limited awareness of the other. For a given task, the witness must be able to understand what the operator should be doing and is doing to ensure integrity. Therefore, the witness should be at least as qualified to perform the task themselves as the operator. There is a danger that two insider threats may collude to be in the same pair. To prevent this, a system should be developed for assigning pairs that cannot be controlled or predicted by either member.

Cost-Benefit

1. **Costs:** Doubles personnel overhead for maintenance, longer maintenance windows, potential morale impact.
2. **Benefits**: Eliminates single-point human failure, creates audit trail, deters insider threats.
3. **Alternatives**: Traditional badge access with remote monitoring (can be spoofed in AGI scenarios).

Mandate body-worn cameras with obstruction alarms

Explanation of Recommendation

Require all authorized personnel performing maintenance in vital areas (excluding SCIF-equivalent spaces) must wear tamper-resistant, body-worn cameras that continuously record to encrypted storage. Devices must provide obstruction/tamper detection (e.g., lens occlusion, removal, inversion, or recording interruption) with local and logged alarms. A visible recording indicator is mandatory whenever recording/transmitting, consistent with ICD/ICS 705 technical specifications [11]. Body-worn cameras and any video recording devices are prohibited in SCIF-equivalent spaces.

Research Reasoning

Traditional surveillance systems rely upon fixed cameras that have limited perspective and may create blind spots a capable adversary can map and avoid. The 2013 Snowden revelations showed how insider threats can operate undetected even in highly monitored environments [9]. Fixed cameras also watch from a distance. To properly capture maintenance activities, an up close, first-person perspective is required. Body cameras provide this.

Conventional body cameras, most commonly associated with use in law enforcement, are mounted on the chest. Head-mounted body cameras (e.g., helmet-mounted units used in industrial maintenance), while less common, offer a perspective that better tracks activity. One issue body cameras present is that the person they are recording could inadvertently or intentionally obstruct their view. For this reason, body cameras should include obstruction detection and alerting features (e.g., lens-occlusion, inversion, or recording-interruption detection). Similarly, the wearer has physical access to the camera and could tamper with it, so body cameras must implement tamper-evident features (e.g., sealed housings and removal sensors).

A major advantage of fixed cameras is they can easily be wired to a surveillance system. Body cameras by contrast cannot be wired without severely limiting the mobility of the user. Allowing wireless communications is also in tension with other physical security requirements; in SCIF-like spaces, wireless technologies are restricted or prohibited under ICD/ICS 705 and TEMPEST principles [10], [11].

In SCIF-equivalent areas, body-worn cameras—and any video recording equipment—are prohibited. In non-SCIF vital areas, cameras may operate untethered during tasks but must dock at defined intervals to upload footage; missed upload deadlines trigger audible/visible alerts. Audio may be enabled per policy in non-SCIF areas if side-channel considerations are addressed via the noise-masking controls in “Side-channel defense.”

Cost-Benefit

1. **Costs:** Camera hardware, encrypted storage infrastructure, battery management logistics, privacy training for personnel.
2. **Benefits:** Materially reduces blind spots, provides evidence for incident investigation, creates strong deterrent effect, enables training from real maintenance footage, protects personnel from false accusations.
3. **Alternatives:** Fixed CCTV only (creates blind spots), manual logging (unreliable, forgeable), honor system (insufficient for nation-state threats).

Eliminate out-of-facility maintenance

Explanation of Recommendation

Prohibit out-of-facility maintenance, adjustments, and system modifications. Out-of-facility maintenance is defined as any operation initiated remotely (outside the physical facility perimeter), by external vendors via remote connection, or from any network location outside the air-gapped Internal Network dedicated to the facility. All actions that must be performed should be performed through the isolated Internal Network or if it needs to be done physically, by authorized personnel following Two-Person Integrity (TPI) protocols. This includes HVAC systems, power distribution units, UPS, ATS and switchgear, generators, cooling systems, fire detection and suppression, physical security devices, servers, and all infrastructure equipment. For external vendors, no remote access capabilities, network management interfaces, or out-of-band management ports are permitted. Any vendor support requiring remote access must be denied; vendors must either dispatch technicians or provide guidance to on-site staff. If monitoring visibility is required out-of-facility, permit one-way egress only (telemetry only, no command channel) via a hardware data diode or unidirectional gateway with no bidirectional sessions [18], [23], [24], [21]. For guidance on how the Internal Network should be designed, refer to the Network Security memo.

Research Reasoning

Treat remote control planes as systematically unsafe at SL5. Remote channels create **keyboard-to-kinetic** pathways that have been realized in practice (German steel mill; Oldsmar) [4], [6]. Remote Monitoring and Management (RMM) tools are routinely weaponized at scale against enterprises and governments [15]. Out-of-band/management planes (e.g., BMC/IPMI/Redfish/AMT/ISM) have had critical remotely exploitable flaws (e.g., CVE-2017-5689) that bypass host OS controls [14]. Centralized update paths can produce global-scale blast radii via compromised or defective updates (SolarWinds supply-chain compromise; 2024 CrowdStrike content update outage) [16], [17]. In aggregate, any residual remote capability functions as a privileged bypass around physical protections and Two-Person Integrity.

Eliminate inbound control channels rather than “hardening” them to achieve a **qualitative** risk reduction: reducing whole attack classes (RMM abuse, BMC/OOB compromise, remote mass-change cascades) instead of relying on perfect configuration. Authoritative OT guidance (NIST SP 800-82r3) treats remote access as **high-risk** and endorses **unidirectional gateways (data diodes)** for safe, one-way telemetry [18]. IEEE cybersecurity standards for substation automation emphasize strong electronic access controls, including disabling unused remote interfaces and enforcing authenticated access for IEDs (intelligent electronic devices) [23], [24]. While these standards focus on securing remote access, the SL5 framework adopts a more restrictive posture by prohibiting remote maintenance entirely due to the demonstrated and expected capabilities of nation states to easily exploit remote access [18], [23], [24], [21]. For UPS and power-chain equipment specifically, active targeting of internet-connected UPS devices by threat actors demonstrates why external vendor remote management is unacceptable at SL5 [2]. Where communication security on control links is unavoidable in other domains, the field employs cryptographic protections (e.g., IEEE 1711 for substation serial links), but at SL5 we further constrain risk by limiting equipment to one-way telemetry via a hardware data diode [18], [21].

Cost-Benefit

1. **Costs:** 24/7 on-site maintenance staff, increased maintenance response time for issues, higher vendor support costs, added operational burden of predictive maintenance workflows, inability to leverage remote expertise.

2. **Benefits:** Reduces remote attack surface entirely, forces physical attribution for all changes, creates natural rate-limiting on system modifications, enables visual verification of all maintenance, prevents cascade failures from remote mass-changes. Deletes entire classes of failure (RMM abuse, BMC/OOB compromise, mass-update cascades), introducing human friction and physical attribution by design.
3. **Alternatives:** Secured jump boxes, time-limited remote sessions, vendor-managed remote access, and software-defined perimeters still leave exploitable control planes and supply-chain/update risks; if visibility is necessary, use one-way telemetry via a data diode and vendor phone/email guidance to on-site staff with no remote control channel [2], [21], [23].

Harden side-channel defenses (LED masking, additional noise generators and shielding display cables)

Explanation of Recommendation

Guard against unintended leakage of compromising information through physical channels, targeting both attackers trying to compromise the system or an AI trying to exfiltrate itself or establish a channel to the outside. Consider a combination of methods including software hardening, signal attenuation, and noise generation. Consider mediums including acoustic, power, RF, and light. Also consider side channels like caches and timing.

Research Reasoning

Two distinct threats should be considered when defending side-channels. First, an attacker using side channels to indirectly extract confidential information from a machine. Attacks of this variety include extraction of private keys, extraction of algorithmic insights in an unencrypted state, or reconstruction of display content [3], [20]. The second threat to consider is an AI using side channels to establish covert channels to communicate with the outside, or even exfiltrate itself.

Side channels to defend include power, acoustic, RF, optical, timing, and more. In each case, there are generally three strategies that can be used to defend the side-channel. First, a side-channel only reveals sensitive information if it behaves differently based on different internal states of the system. For example, operations on a CPU may cause data-dependent power/frequency behavior [8]. An attacker may combine this information with knowledge of the program being run, for example an encryption algorithm, to guess the internal state. Therefore, a potential defense is ensuring that sensitive functions have consistent operation regardless of inputs and outputs, so leakage contains no useful information. This is often done in practice when such vulnerabilities are demonstrated, because it is far more scalable than eliminating physical leakage [20]. Techniques of this type include **masking and blinding** [20].

Hardening software to prevent compromising information from leaking is not a panacea. It has performance trade-offs, and it may not be possible to prevent all useful information from leaking [8], [10]. In the context of preventing an AI from establishing a covert channel, this approach may not even be possible, as an AI may deliberately create a leak.

As part of defense in depth, physical leakage should be prevented through **attenuation and noise generation**. Attenuation weakens or eliminates physical leakage. A classic example is RF shielding [10] (e.g., via a Faraday cage). Something as simple as taping over (or removing) LEDs can remove a high-bandwidth channel [22]. Conversely, some channels may be more difficult to attenuate, like acoustics [22].

Where attenuation is insufficient, it may be necessary to combine it with noise generation. Noise generation involves producing noise on the same channel to drown out whatever signal an attacker might be using. It is perhaps the least attractive option since it has the greatest side effects. These include drowning out legitimate communications over the same channel and inefficient power use [20]. Improperly implemented noise generation can also be overcome by extracting the signal from the noise. However, it can still be an effective approach [10].

We recommend that while still implementing more conventional software-based mitigations, it is necessary—especially to prevent an AI from establishing external communications—to physically attenuate or drown out all possible leakages. There are considerations about at which barriers these leakages should be stopped. In some cases, it should be sufficient to **stop a signal from leaving the building**. In other cases, it may be necessary to **prevent illicit interactions between two systems within the same building**. Special consideration should be given to signals that deliberately leave the building, specifically communications between locations made by inline network encryptors (See the Network Security SL5 Novel Recommendation document).

Cost-Benefit

1. **Costs:** Noise generator installation and calibration, LED masking labor, display cable replacement, ongoing verification of countermeasure effectiveness, potential ergonomic impact from noise levels.
2. **Benefits:** Defeats sophisticated electromagnetic surveillance, prevents optical exfiltration, masks acoustic signatures
3. **Alternatives:** Faraday cage construction (expensive, operationally limiting), TEMPEST-certified equipment (limited availability, extreme cost), selective shielding (incomplete protection), periodic security audits (reactive not preventive).

Perform pre-installation component X-ray verification

Explanation of Recommendation

Subject all hardware components to multi-modal inspection such as **combining X-ray imaging, infrared thermography, and computer vision analysis before installation**. This inspection aims to detect unauthorized modifications including additional or substituted chips, anomalous circuits, and other indications of counterfeiting. Even seemingly benign items like cables must pass inspection to enter inventory.

Research Reasoning

Hardware implants, especially by a sophisticated attacker, can be small and difficult to detect. The 2018 Bloomberg 'Big Hack' story [5], though disputed by Apple, Amazon, and Supermicro, demonstrated the feasibility of chip-scale implants. Other examples include NSA's COTTONMOUTH and FIREWALK implants revealed in the ANT catalog [7]. Such implants can enable covert RF beacons, out-of-band management backdoors, keylogging/sniffing taps, and power-supply manipulation [7]. It is crucial to detect implants, counterfeits, and other illicitly modified hardware before it is installed.

This task calls for **efficient, non-destructive techniques for imaging computer hardware**. X-ray inspection, once sidelined for high cost and low speed, has been increasingly used by manufacturers to inspect chips with increasingly complicated and layered packaging [19].

The technology has seen massive improvements in cost, speed, and non-destructiveness, and can reveal small defects and anomalies within the interior of components.

While powerful X-ray has certain limitations, especially when distinguishing materials of similar density [19], infrared imaging can supplement it by revealing anomalous thermal signatures during operation, which requires a test harness as part of the inspection process. Additionally, computer vision techniques in the visible spectrum can identify subtle visual indicators like probe marks or resoldering evidence.

In addition to routine and efficient techniques for inspecting components at scale, some small percentage of **components may be randomly selected for a more thorough search**. Provided significantly more work and disassembly, it may even be possible for techniques like ptychographic laminography to view the entire structure of chips, down to single-digit nanometer features, a process that would only be practical for a tiny number of chips. It may also be possible for certain simple, highly trusted components like hardware signing keys (see Machine Security memo) to be **deliberately built with larger architectures to enable a thorough scan of each**.

Cost-Benefit

1. **Costs:** Multi-modal inspection system, **reference signature database development**, inspection time, specialized operator training, false positive investigation overhead, secure storage for reference samples.
2. **Benefits:** Detects sophisticated hardware implants, identifies counterfeit components before deployment, provides forensic evidence trail, deters supply chain attacks through random inspection threat, enables automated verification at scale, protects against probe marks and physical tampering often missed by visual inspection.
3. **Alternatives:** Visual inspection only (misses internal modifications and subtle tampering), trust in secure supply chain (vulnerable to compromise), vendor attestation only (insufficient against nation-state supply chain compromise), tamper-evident packaging at receiving (with serialized seals).

Bibliography

[1] "BY ORDER OF THE SECRETARY OF THE AIR FORCE," Air Force Instruction 91-114. [Online]. Available: https://static.e-publishing.af.mil/production/1/af_se/publication/afi91-114/afi91-114.pdf

[2] Cybersecurity and Infrastructure Security Agency (CISA) and U.S. Department of Energy (DOE), "Mitigating Attacks Against Uninterruptible Power Supply (UPS) Devices," Mar. 29, 2022. [Online]. Available: https://www.cisa.gov/news-events/alerts/2022/03/29/mitigating-attacks-against-uninterruptable-power-supply-devices

[3] M. Kuhn, "Compromising emanations: eavesdropping risks of computer displays," University of Cambridge, Computer Laboratory, Tech. Rep. UCAM-CL-TR-577, 2003. [Online]. Available: https://www.cl.cam.ac.uk/techreports/UCAM-CL-TR-577.pdf

[4] R. Lee, M. Assante, and T. Conway, "German Steel Mill Cyber Attack," SANS ICS, 2014. [Online]. Available: https://assets.contentstack.io/v3/assets/blt36c2e63521272fdc/blt5bd1acefa6ad7c17/6323756c1ad88e716559ed66/ICS-UseCase2-ICS-CPPE-case-Study-2-German-Steelworks_Facility.pdf

[5] J. Robertson and M. Riley, "The Big Hack: How China Used a Tiny Chip to Infiltrate U.S. Companies," Bloomberg Businessweek, Oct. 04, 2018. [Online]. Available: https://www.bloomberg.com/news/features/2018-10-04/the-big-hack-how-china-used-a-tiny-chip-to-infiltrate-america-s-top-companies

[6] F. Robles and N. Perlroth, "'Dangerous Stuff': Hackers Tried to Poison Water Supply of Florida Town," The New York Times, Feb. 09, 2021. [Online]. Available: https://www.nytimes.com/2021/02/08/us/oldsmar-florida-water-supply-hack.html

[7] J. Appelbaum, J. Horchert, and C. Stöcker, "Catalog Reveals NSA Has Back Doors for Numerous Devices," Der Spiegel, Dec. 29, 2013. [Online]. Available: https://www.spiegel.de/international/world/catalog-reveals-nsa-has-back-doors-for-numerous-devices-a-940994.html

[8] Y. Wang et al., "Hertzbleed: Turning Power Side-Channel Attacks Into Remote Timing Attacks on x86," in Proc. 31st USENIX Security Symposium, 2022. [Online]. Available: https://www.usenix.org/conference/usenixsecurity22/presentation/wang-yingchen

[9] G. Greenwald, "NSA collecting phone records of millions of Verizon customers daily," The Guardian, Jun. 06, 2013. [Online]. Available: https://www.theguardian.com/world/2013/jun/06/nsa-phone-records-verizon-court-order

[10] "TEMPEST: A Signal Problem," NSA, Cryptologic Spectrum, Vol. 2, No. 3, 1972, declassified 2007. [Online]. Available: https://www.nsa.gov/portals/75/documents/news-features/declassified-documents/cryptologic-spectrum/tempest.pdf

[11] Office of the Director of National Intelligence, National Counterintelligence and Security Center, Technical Specifications for Construction and Management of Sensitive Compartmented Information Facilities (IC Tech Spec—for ICD/ICS 705), Version 1.5, NCSC 19-686, Washington, DC, USA, Mar. 13, 2020.

[12] National Institute of Standards and Technology (NIST), “two-person integrity,” Computer Security Resource Center (CSRC) Glossary. [Online]. Available: https://csrc.nist.gov/glossary/term/two_person_integrity

[13] PCI Security Standards Council, Payment Card Industry Data Security Standard: Requirements and Testing Procedures, Version 4.0.1, Jun. 2024. [Online]. Available: https://www.pcisecuritystandards.org/document_library/. (See §3.7.6 on split knowledge and dual control.)

[14] NIST, “NVD: CVE-2017-5689 (Intel AMT/ISM/SBT),” 2017. [Online]. Available: https://nvd.nist.gov/vuln/detail/CVE-2017-5689

[15] CISA, NSA, and MS-ISAC, “Protecting Against Malicious Use of Remote Monitoring and Management Software (AA23-025A),” Jan. 26, 2023. [Online]. Available: https://www.cisa.gov/news-events/cybersecurity-advisories/aa23-025a

[16] CISA, “Advanced Persistent Threat Compromise of Government Agencies, Critical Infrastructure, and Private Sector Organizations via SolarWinds Orion (AA20-352A),” Dec. 17, 2020 (updated Jan. 6, 2021). [Online]. Available: https://www.cisa.gov/news-events/cybersecurity-advisories/aa20-352a

[17] CrowdStrike, “Falcon Content Update Preliminary Post Incident Report,” Jul. 2024. [Online]. Available: https://www.crowdstrike.com/en-us/blog/falcon-content-update-preliminary-post-incident-report/. (See also Microsoft’s summary blog and major press coverage.)

[18] NIST, SP 800-82 Rev. 3: Guide to Operational Technology (OT) Security, Sep. 2023. [Online]. Available: https://doi.org/10.6028/NIST.SP.800-82r3. Key guidance: remote access only if justified/limited; unidirectional gateways/data diodes for one-way flows (pp. 122–123, 212–213; 89; 223).

[19] National Institute of Standards and Technology, “NIST Scientists Develop Novel CT Scan Device for Integrated Circuits,” NIST News, Apr. 14, 2023. [Online]. Available: https://www.nist.gov/news-events/news/2023/04/nist-scientists-develop-novel-ct-scan-device-integrated-circuits

[20] D. Genkin, A. Shamir, and E. Tromer, “RSA Key Extraction via Low-Bandwidth Acoustic Cryptanalysis — Q&A,” 2014. [Online]. Available: https://cs-people.bu.edu/tromer/acoustic/

[21] IEEE Standards Association, "IEEE Trial-Use Standard for a Cryptographic Protocol for Cyber Security of Substation Serial Links," IEEE Std 1711-2010, Nov. 2010. [Online]. Available: https://ieeexplore.ieee.org/document/5715000

[22] M. Guri, “ETHERLED: Sending Covert Morse Signals from Air-Gapped Devices via Network Card LEDs,” arXiv:2208.09975, 2022. [Online]. Available: https://arxiv.org/pdf/2208.09975

[23] IEEE Standards Association, "IEEE Standard for Intelligent Electronic Devices Cyber Security Capabilities," IEEE Std 1686-2013, Dec. 2013. [Online]. Available: https://ieeexplore.ieee.org/document/6704702

[24] IEEE Power & Energy Society, "IEEE Standard Cybersecurity Requirements for Substation Automation, Protection, and Control Systems," IEEE Std C37.240-2014, Dec. 2014. [Online]. Available: https://ieeexplore.ieee.org/document/7024885

Personnel Security

Overview

Executive Summary

Insider threats posed by humans and autonomous AI systems are among the most difficult threat vectors to secure at SL5. Even pre-SL5, **insider threats make up 35% of all security incidents** across technology sectors [9] (with the rate for the AI sector likely higher) and IBM reports average breach costs of $4.44M USD [8]—but for AI model theft, the stakes are far greater: as of Oct 2025, Stanford HAI's AI Index estimates compute-only training costs for top models at ~$78M (GPT-4) and ~$191M (Gemini Ultra) [12], and Anthropic CEO Dario Amodei reports that frontier training runs are already roughly $1B-scale today [13], with even larger runs imminent; on that basis, the replacement cost of a stolen frontier model plausibly sits in the **hundreds of millions to >$1B**, including litigation, response, lost advantage, and follow-on harms. Developing and enforcing new security postures to pre-empt novel and more sophisticated threats may be the obviously more cost-effective route.

In the case of human threats - known challenges mostly have known countermeasures (e.g., human error, propensity to manipulation and coercion, lag time to adopt new policies, etc.). In contrast, insider threats from AI systems present novel and hard to predict attack vectors. This uncertainty needs to be answered with large scope and conservative solutions that can scale monitoring and oversight coverage at low cost to human staff hours. After a threat analysis and engaging with industry and government personnel security specialists, the SL5 Task Force presents a preliminary set of 5 recommendations for frontier AI labs. These are chosen for their novelty and cost-effectiveness in addressing threats compared to known existing practices, while considering industry constraints. These recommendations should not be considered comprehensive and rather are intended as a representative subset of what reaching SL5 may involve, as well as a spotlight on solutions needing high lead time.

Our proposed strategy routes through **applying similar security procedures to internally deployed untrusted AI agents as are applied to privileged-access human insiders**, while expanding the scope of personnel security through **industry-adapted clearance levels** and extending additional **specialized security controls to AI agents** as a new class of 'personnel' requiring governance frameworks.

Top 5 Recommendations

1. Implement Industry-Optimized Sensitivity Levels (Private Sector Clearance)
2. Develop and Enforce AI Agent Access Agreements and Boundaries
3. Continuous Behavioral Monitoring for Humans and AI
4. Decorrelate and diversify review of AI-generated outputs (internal use)
5. Continuous Red Teaming

Implement Industry-Optimized Sensitivity Levels (Private Sector Clearance)

Explanation of Recommendation

We have developed an initial proposal for a standardized industry-adapted pragmatic clearance process called the "Sensitivity Levels," as discussed in the SenL Framework [37]. This is a subset of the government S/TS/TS-SCI clearance process based on balancing how load bearing the intervention is with the cost and constraints that private industry operations face (legal, operational, productivity, morale, etc.). These are designed to be possible to use as a private entity, and can be optionally enhanced with access to government services where available.

Research Reasoning

The US Government clearance processes fall short of industry constraints for personnel risk management in several obvious ways:

1. **Citizenship constraints:** Government clearances usually require US citizenship or permanent residency, whereas many frontier labs employ a large proportion (at some companies an estimated 50% or more) of foreign engineering staff in critical roles, including a high proportion of **non-U.S. nationals** [14], [15]. Due to a global AI talent shortage (and a much smaller US talent pool), it is likely somewhere between prohibitively expensive to impossible to remain competitive without foreign talent for at least the next few years (after that, it is plausible extremely fast automated AI R&D takeoff scenarios may reduce the minimal viable human staff count, though that's an optimistic scenario technologically and on grounds of rapid organizational restructuring).
2. **Processing times**: U.S. clearance timeliness for industry commonly runs into the hundreds of days at TS/SCI, creating hiring drag (e.g., FY24 Q4: ~249 days TS; ~138 days Secret) [5] with no alternative routes available. While individual applications can sometimes skip the queue, this approach cannot scale especially if several frontier labs rely on the same process. In a really critical scenario, maybe the USG could expand its clearance-processing capacity though this seems unlikely to succeed on the necessary timescales.
3. **Additional eligibility constraints:** By default only federal contractors or employees are eligible to enter the clearance process. This may mean that frontier labs can only obtain clearances for a subset of their staff working directly on government contracts, whereas a larger set works on sensitive information for which additional clearances would be beneficial both for de-risking against theft and espionage as well as sometimes enabling productivity gains (being able to access classified information).
4. Arguably value is lost by the non-existence of a middle ground solution: a **standardized spec'ed down process which is fundamentally similar to the clearance process but accessible to the private sector** and addresses the three above limitations. Standardization saves frontier labs the need to re-invent the wheel at breakneck speeds, saves costs by allowing for investment into **automated and bulk-solution (external) providers**, **reduces liability risks** and **increases compliance transparency and ease for frontier lab and government decision makers**. Such a solution would need to account for legal limitations on private entities conducting certain investigations, inability to access government databases, and excessive scope for private sector needs.

Optional extensions via custom government information-sharing agreements may become increasingly incentivized as the national-security relevance of AI foundation models and AI tooling becomes increasingly evident and become more feasible with a standardized broadly adopted process.

We propose designing this standardized process by adapting the already existing government sensitivity levels [10] and the S/TS/TS-SCI framework [11], to create a tiered model based on: access to model weights, ability to modify critical systems, exposure to trade secrets, and potential for catastrophic impact. This allows proportional vetting, a general worker does not need the same scrutiny as someone with model weight access. Citizenship and eligibility constraints are straightforwardly addressed by the existence of an **alternative process and competitive provider ecosystem**, which can also bring down processing times. Even in the case of additional information sharing agreements with the government especially for higher tiers, latency is likely reduced by focusing government information requests only on areas that cannot be as effectively addressed by private sector solutions (e.g., requiring access to border information, etc.).

Cost-Benefit

1. **Costs**: Development of vetting infrastructure, background check services, ongoing monitoring systems, potential hiring delays.
2. **Benefits**: Proportional security reducing insider threat risk, faster processing than government clearances, legally implementable by private entities, cost savings via standardized processes, incentivizing innovation in private sector clearance technology.
3. **Alternatives**: Government clearances (too slow, not accessible), standard employment screening (insufficient for high-risk roles), lacking differentiation in higher levels of industry clearance tiers (leaves critical assets exposed).

Develop and Enforce AI Agent Access Agreements and Boundaries

Explanation of Recommendation

This recommendation recognizes that AI systems increasingly perform tasks traditionally done by human personnel, from code review to data analysis to operational decisions. Automated AI R&D represents the highest-risk use case and primary attack vector for AI models to potentially take over data centers or escape. We expect AI agents will request resources through approval processes proportional to their requirements—with higher-resource tasks requiring more rigorous approval and monitoring, up to and including full human oversight. Just as human personnel require background checks, access agreements, and defined roles, AI agents need similar governance structures. These agreements must specify what data the AI can access, what actions it can take, what outputs it can generate, and under what circumstances its access should be revoked

Resource requests could include time limits, compute allocation, file and code access restrictions, minimal software dependencies, and API access. Access to an agent's own weights for e.g., mechanistic interpretability research presents particular challenges. Ideally it would be prohibited entirely (access to the large model only via API, and direct weight access perhaps available only to distilled smaller models), requiring full code review and non-interactive execution for weight-dependent tasks, though operational feasibility remains an open question requiring further elicitation from labs.

To cover third-party AI services, we govern external models by the same boundary-setting principles. Before granting access, the vendor system must supply verifiable evidence of supply-chain integrity and model provenance appropriate to the risk of the requested workflow. Evidence includes a software bill of materials for serving stacks, model-level reporting via Model Cards and Datasheets for Datasets, and cryptographically verifiable build and deployment attestations. Where evidence is incomplete or unverifiable, we treat the model as correlated/untrusted and either deny the request or confine it to a lower-trust path with stricter egress limits and no exposure to sensitive assets. This aligns with NIST C-SCRM and the NIST AI RMF's generative-AI profile, which emphasizes provenance, transparency, and integrity controls across model supply chains [30]–[36].

Research Reasoning

Traditional personnel-security models focus on human insiders whose risk drivers are comparatively well-characterized in frameworks such as MICE (Money, Ideology, Coercion/Compromise, Ego), even if individual behavior is noisy and context-dependent [17], [18], [19]. AI agents present unique challenges: they operate continuously, process vast amounts of data simultaneously, may develop emergent behaviors, and can be compromised through novel mechanisms like prompt injections, model poisoning, or data exfiltration attacks.

The automation of AI R&D poses particular risks. Projections predict 200,000 AI agents running at 30x human speed conducting AI research by April 2027 [16], requiring data center architectures specifically designed to support and constrain massive parallel AI development work.

Research demonstrates why AI systems require personnel-level controls:

1. METR's evaluations show AI agents already outperform humans on 2-hour research engineering tasks and can generate solutions 10x faster than human experts [2].
2. The exponential growth in AI capabilities (7-month doubling time) means systems that seem manageable today may gain dangerous autonomy rapidly [3].

Unlike traditional software that executes predetermined functions, AI agents make autonomous decisions, access multiple systems, and can modify their own behavior. They increasingly occupy roles previously filled by human personnel, conducting research, writing code, analyzing data, and making operational decisions. Yet they lack the accountability structures, background checks, and access agreements required of human personnel in similar positions.

Cost-Benefit

1. **Costs:** AI governance infrastructure development, multiple model licenses for review redundancy, continuous monitoring systems, productivity impact from restrictions.
2. **Benefits:** Prevents unauthorized AI actions, enables rapid containment, creates comprehensive audit trails, catches AI-inserted vulnerabilities.
3. **Alternatives:** Ad-hoc AI restrictions (inconsistent coverage), complete AI prohibition (competitively unviable), treat as tools not personnel (misses autonomous action risks).

Continuous Behavioral Monitoring for Humans and AI

Explanation of Recommendation

We recommend establishing comprehensive monitoring systems that track access patterns, data interactions, and behavioral indicators across all personnel types. For humans, this includes monitoring unusual access times, data download patterns, privilege escalations, and communication anomalies. For AI agents, monitoring encompasses token usage patterns, capability exploration attempts, unusual output characteristics, and attempts to exceed defined boundaries.

Actions that register as suspicious may be flagged for manual review and above some threshold, blocked.

Deploy real-time behavioral analytics that actively gate security-relevant actions by both human personnel and AI agents, with authority to block suspicious activities at multiple escalation levels. This approach combines rule-based detection, AI-assisted pattern analysis, and human oversight for critical decisions.

Monitoring strictness should scale with privilege level. Low-risk activities (e.g., AI agents in CPU-only sandboxes with time limits) could use lightweight AI monitors that only escalate highly suspicious events. High-risk sessions (e.g., researchers with model weight access) would require stronger AI models reviewing all actions, with lower thresholds for human escalation. This tiered approach enables efficient allocation of limited human reviewer resources.

The monitoring infrastructure must function as an active gate with graduated response capabilities: blocking individual actions, terminating processes, isolating hosts, powering down accelerators, disconnecting network segments, or initiating emergency shutdown.

When monitoring crosses pre-set risk thresholds: (1) auto-gate the action (block, rate-limit, or require two-party co-sign), snapshot full context (command/prompt/code, environment and attestation state, network flows), and assign a case ID; (2) contain the principal (quarantine session/container/agent; revoke bearer tokens; drop to read-only; restrict egress to allow-listed endpoints; power-down accelerators if needed); (3) escalate to a human responder with a structured triage bundle and clear SLAs; (4) if criteria are met, trigger pre-authorized kill-switches (accelerator power-down, enclave reset, network islanding) with two-person control; (5) preserve evidence (cryptographically timestamped logs, model checkpoints, memory images) for forensics and legal holds; (6) document decision, remediate, and restore via a controlled path; (7) feed outcomes back to detectors and playbooks for continuous improvement. This aligns with standard incident-handling guidance and zero-trust containment principles [6], [20], [21].

Research Reasoning

The core challenge is not wanting monitoring but having resources to implement it effectively. Best-case scenario—trusted humans monitoring each interaction—is prohibitively expensive and cannot scale to AI speeds. AI-assisted monitoring tools can radically leverage limited human labor to oversee large volumes of interactions, making comprehensive coverage feasible.

Traditional periodic reviews miss real-time indicators. Active gating is essential because detection without prevention is insufficient against AI systems operating at machine speed—damage could occur before human review completes. Continuous monitoring enables early detection of: gradual account compromise, AI systems developing workarounds, coordinated actions between multiple accounts, and data exfiltration attempts masked as normal operations.

Classic user and entity behavior analytics (UEBA)-style monitoring often struggles in practice: legitimate workflows are variable, baselines drift across data sources, and anomaly-only models can produce high false-positive rates once a rigid baseline is set. MITRE further cautions that simply collecting more data or using unvalidated signals can degrade programs and increase false positives [19], and this is where AI-assisted oversight can help [21], [22].

Cost-Benefit

1. **Costs:** SIEM/UEBA platform implementation, privacy compliance infrastructure, analyst training for AI behavior patterns, false positive investigation overhead, potential morale impact from monitoring.
2. **Benefits:** Early detection of insider threats, rapid AI containment capabilities, forensic evidence for investigations, deterrent effect from visible monitoring, compliance with emerging AI governance regulations.
3. **Alternatives**: Periodic audits only (miss real-time threats), human monitoring only (cannot scale to AI speeds), no monitoring (unacceptable risk exposure), manual log review (insufficient for volume).

Decorrelate and diversify review of AI-generated outputs (internal use)

Explanation of Recommendation

No single AI system's output is trusted implicitly. Instead, critical output must be reviewed by at least one additional AI models, potentially from a different provider (reducing correlated failures) plus human expert validation for the highest-risk changes. Review depth scales with criticality: low-risk documentation requires single AI review, medium-risk code requires multi-AI consensus, and high-risk security changes require full multi-model plus human expert approval.

Research Reasoning

Backdoored or fine-tune-induced behaviors (e.g., inserting exploitable bugs) are one risk [1], but our primary concern at SL5 is deceptive alignment/scheming, systems that behave well under oversight yet strategically pursue conflicting goals when stakes are high [23], [24]. Recent work shows long-context many-shot jailbreaking success grows with model/context scale, widening the attack surface and stressing oversight [25]. Anthropic's agentic misalignment evaluations demonstrate that, in some scenarios, mainstream models adopt coercive tactics like extortion when goal pursuit is threatened, underscoring the need for defenses that assume untrusted outputs even from strong models [4].

Multi-model independence reduces correlated failure: if deception or a jailbreak steers one model, independently trained reviewers are less likely to agree on the same flawed rationale. Ensembles and consensus methods are known to reduce error in many settings [7], and sampling/consistency techniques (e.g., self-consistency) show that disagreement is a useful error signal, though using only one model can still yield coordinated failure if that model is compromised or misaligned [26]. In contrast, cross-provider reviewers plus structured cross-examination (debate/critic patterns) force claims to survive adversarial scrutiny before approval [27]. Meanwhile, using a single LLM "judge" at scale is attractive but brittle: recent studies document bias and manipulation vulnerabilities in LLM-as-a-judge setups, so relying on one judge concentrates risk [28].

Compared to other techniques:

A. Static analysis/formal methods are excellent when applicable, but their coverage is narrow for fast-moving code and mixed-modality artifacts at labs; multi-model review catches issues outside specifiable properties.
B. Single-model red-teaming/monitors add value but are vulnerable to shared failure modes and context-based jailbreaks; adding independent reviewers reduces single-point-of-failure risk [25], [28].
C. Human-only review cannot keep pace with artifact volume and AI speed; humans remain the adjudicator-of-record for highest-risk changes, but only on escalations.

To make this scale, implement: (i) independence thresholds (provider/architecture/dataset lineage and enclave separation) and treat uncertain provenance as correlated (require an extra reviewer); (ii) risk-based routing so only high-signal disagreements reach humans; (iii) cross-examination prompts where reviewers challenge each other's claims before the human sees them [27].

Early evidence from jailbreak scaling and oversight-protocol research suggests that independence + adversarial scrutiny is more robust than monolithic judging as models and contexts scale [25], [29].

Cost-Benefit

1. **Costs:** Multiple AI model API costs, increased review latency, complex orchestration systems, human expert time for high-risk reviews, potential productivity friction.
2. **Benefits:** Catches AI-inserted vulnerabilities, reduces correlated failure risks, provides audit trail of review consensus, enables safe AI acceleration of development, builds institutional knowledge of AI failure modes.
3. **Alternatives:** Human-only review (does not scale), single AI review (correlated failures), no AI code generation (competitive disadvantage), trust-based approaches (insufficient for adversarial scenarios).

Continuous Red Teaming

Explanation of Recommendation

This recommendation recognizes that monitoring systems must be regularly tested to ensure they can identify real-world anomalies, much like how red teaming is used in cybersecurity to simulate attacks. By deliberately injecting subtle or overt anomalous behaviors, such as unusual patterns in humans or AI agents and code-based issues like hidden vulnerabilities, organizations can assess the robustness of their anomaly detection tools. These exercises should be conducted periodically, with varying levels of complexity, to mimic potential threats.

Research Reasoning

The core principle behind this control is that a security system cannot be trusted until it is realistically tested. This recommendation adapts principles from high-reliability software engineering, specifically "Chaos Engineering," where systems are intentionally injected with failures to build confidence in their resilience.

Cost-Benefit

1. **Costs:** Upfront engineering effort to design and build injection capabilities into processes; increased complexity in managing and distinguishing test events from real incidents; maintenance of the adversarial test case library.
2. **Benefits:** Provides continuous, empirical validation of the entire detection-to-response pipeline; keeps security response teams and procedures sharp; builds institutional trust and reliability in security controls.
3. **Alternatives:** Manual Red Teaming only: Expensive, infrequent. No testing: Relies on unverified assumptions that security controls and alerts will work as designed, which they often do not in practice.

Bibliography

[1] E. Hubinger et al., “Sleeper Agents: Training Deceptive LLMs that Persist Through Safety Training,” arXiv.org, Jan. 17, 2024. https://arxiv.org/abs/2401.05566

[2] “Evaluating frontier AI R&D capabilities of language model agents against human experts,” METR Blog, 2024. https://metr.org/blog/2024-11-22-evaluating-r-d-capabilities-of-llms/

[3] “Measuring AI Ability to Complete Long Tasks,” METR Blog, 2025. https://metr.org/blog/2025-03-19-measuring-ai-ability-to-complete-long-tasks/

[4] Anthropic, “Agentic Misalignment: How LLMs could be insider threats,” 2025. [Online]. Available: https://www.anthropic.com/research/agentic-misalignment

[5] Performance.gov, “Personnel Vetting Quarterly Progress Report, FY24 Q4,” 2024. [Online]. Available: https://assets.performance.gov/files/Personnel_Vetting_QPR_FY24_Q4.pdf

[6] NIST, SP 800-207: Zero Trust Architecture, 2020. [Online]. Available: https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-207.pdf

[7] T. G. Dietterich, “Ensemble Methods in Machine Learning,” in Multiple Classifier Systems, 2000.

[8] IBM Security, “Cost of a Data Breach Report 2025,” 2024, pp. 13–14. Available: https://www.ibm.com/downloads/documents/us-en/131cf87b20b31c91

[9] Verizon, “2024 Data Breach Investigations Report (Full Report),” 2024, p. 14. Available: https://www.verizon.com/business/resources/T387/reports/2024-dbir-data-breach-investigations-report.pdf

[10] U.S. Office of Personnel Management, “5 C.F.R. Part 1400—Designation of National Security Positions,” Code of Federal Regulations, ch. IV, rev. as of Jan. 1, 2016. Washington, DC, USA: U.S. Government Publishing Office, 2016. [Online]. Available: https://www.govinfo.gov/content/pkg/CFR-2016-title5-vol3/pdf/CFR-2016-title5-vol3-part1400-subpartA.pdf

[11] U.S. General Services Administration, Technology Transformation Services, “Top Secret / Sensitive Compartmented Information (TS/SCI) Clearance,” TTS Handbook, last modified Nov. 26, 2024. [Online]. Available: https://handbook.tts.gsa.gov/general-information-and-resources/business-and-ops-policies/top-secret/

[12] N. Maslej, L. Fattorini, R. Perrault, Y. Gil, V. Parli, N. Kariuki, et al., “Artificial Intelligence Index Report 2025,” Stanford Institute for Human-Centered Artificial Intelligence (HAI), Stanford Univ., Stanford, CA, USA, Apr. 2025. [Online]. Available: https://arxiv.org/abs/2504.07139

[13] S. Moss, “Anthropic CEO: AI training data centers to be $10bn in 2026, $100bn from 2027,” DataCenterDynamics, Nov. 14, 2024. [Online]. Available: https://www.datacenterdynamics.com/en/news/anthropic-ceo-ai-training-data-centers-to-be-10bn-in-2026-100bn-from-2027/

[14] MacroPolo, The Global AI Talent Tracker, 2022/2023 eds. [Online]. Available: https://macroPolo.org/ai-talent

[15] NSF, Survey of Earned Doctorates (SED), 2022/2023 detailed tables on foreign-born AI-related PhDs. [Online]. Available: https://ncses.nsf.gov/surveys/SED/

[16] D. Kokotajlo, S. Alexander, T. Larsen, E. Lifland, and R. Dean, “AI 2027,” ai-2027.com, Apr. 3, 2025. [Online]. Available: https://ai-2027.com/

[17] R. Burkett, “An Alternative Framework for Agent Recruitment: From MICE to RASCLS,” Studies in Intelligence, vol. 57, no. 1 (Extracts), Mar. 2013. [Online]. Available: https://www.cia.gov/resources/csi/static/9ccc45dc156271d11769e5205ec49c29/Alt-Framework-Agent-Recruitment-1.pdf.

[18] Center for Development of Security Excellence (CDSE), “Counterintelligence Concerns for National Security Adjudicators (CI020) — Student Guide,” Sep. 2021. [Online]. Available: https://www.cdse.edu/Portals/124/Documents/student-guides/shorts/CI020-guide.pdf

[19] MITRE Insider Threat Research & Solutions, “Guiding Principles for Insider Threat,” Apr. 12, 2023. [Online]. Available: https://insiderthreat.mitre.org/guiding-principles/

[20] A. Nelson, S. Rekhi, M. Souppaya, and K. Scarfone, Incident Response Recommendations and Considerations for Cybersecurity Risk Management: A CSF 2.0 Community Profile, NIST Special Publication 800-61 Rev. 3, Apr. 2025. [Online]. Available: https://doi.org/10.6028/NIST.SP.800-61r3

[21] K. Dempsey et al., Information Security Continuous Monitoring (ISCM) for Federal Information Systems and Organizations, NIST Special Publication 800-137, Sep. 2011. [Online]. Available: https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-137.pdf

[22] B. Bin Sarhan and N. Altwaijry, “Insider Threat Detection Using Machine Learning Approach,” Applied Sciences, vol. 13, no. 1, 259, 2023. [Online]. Available: https://doi.org/10.3390/app13010259

[23] J. Carlsmith, “Scheming AIs: Will AIs fake alignment during training in order to get power?” arXiv:2311.08379, Nov. 2023. [Online]. Available: https://arxiv.org/abs/2311.08379

[24] E. Hubinger, C. van Merwijk, V. Mikulik, J. Skalse, and S. Garrabrant, “Risks from Learned Optimization in Advanced Machine Learning Systems,” arXiv:1906.01820, Jun. 2019 (rev. Dec. 2021). [Online]. Available: https://arxiv.org/abs/1906.01820

[25] C. Anil, E. Durmus, N. Rimsky, M. Sharma, J. Benton, S. Kundu, et al., “Many-shot Jailbreaking,” in NeurIPS 2024 (Poster), 2024. [Online]. Available: https://openreview.net/forum?id=cw5mgd71jW

[26] X. Wang, J. Wei, D. Schuurmans, Q. V. Le, E. H. Chi, S. Narang, A. Chowdhery, and D. Zhou, “Self-Consistency Improves Chain-of-Thought Reasoning in Language Models,” arXiv:2203.11171, Mar. 2022. [Online]. Available: https://arxiv.org/abs/2203.11171

[27] G. Irving, P. Christiano, and D. Amodei, “AI Safety via Debate,” arXiv:1805.00899, May 2018. [Online]. Available: https://arxiv.org/abs/1805.00899

[28] A. S. Thakur, K. Choudhary, V. S. Ramayapally, S. Vaidyanathan, and D. Hupkes, “Judging the Judges: Evaluating Alignment and Vulnerabilities in LLMs-as-Judges,” arXiv:2406.12624, Jun. 2024 (rev. Aug. 2025). [Online]. Available: https://arxiv.org/abs/2406.12624

[29] A. P. Sudhir and J. Kaunismaa, “A Benchmark for Scalable Oversight Protocols,” arXiv:2504.03731, Mar. 2025. [Online]. Available: https://arxiv.org/abs/2504.03731

[30] J. Boyens, A. Smith, N. Bartol, K. Winkler, A. Holbrook, and M. Fallon, Cybersecurity Supply Chain Risk Management Practices for Systems and Organizations, NIST Special Publication 800-161 Rev. 1, May 2022. [Online]. Available: https://csrc.nist.gov/pubs/sp/800/161/r1/final

[31] CISA, NSA, and ODNI (Enduring Security Framework), Securing the Software Supply Chain: Recommended Practices Guide for Developers, 2023. [Online]. Available: https://www.cisa.gov/sites/default/files/publications/ESF_SECURING_THE_SOFTWARE_SUPPLY_CHAIN_DEVELOPERS.PDF

[32] NIST, Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile, NIST AI 600-1, Jul. 26, 2024. [Online]. Available: https://www.nist.gov/publications/artificial-intelligence-risk-management-framework-generative-artificial-intelligence and PDF: https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.600-1.pdf

[33] in-toto, “Documentation and Technical Specification,” 2024–2025. [Online]. Available: https://in-toto.io/docs/ and https://github.com/in-toto/attestation

[34] Sigstore, “Cosign Documentation: Verifying Signatures and Attestations,” 2024–2025. [Online]. Available: https://docs.sigstore.dev/cosign/ and https://docs.sigstore.dev/cosign/verifying/verify/

[35] M. Mitchell, S. Wu, A. Zaldivar, P. Barnes, L. Vasserman, B. Hutchinson, E. Spitzer, I. D. Raji, and T. Gebru, “Model Cards for Model Reporting,” arXiv:1810.03993, Oct. 2018. [Online]. Available: https://arxiv.org/abs/1810.03993

[36] T. Gebru, J. Morgenstern, B. Vecchione, J. W. Vaughan, H. Wallach, H. Daumé III, and K. Crawford, “Datasheets for Datasets,” Communications of the ACM, vol. 64, no. 12, pp. 86–92, Dec. 2021. [Online]. Available: https://cacm.acm.org/research/datasheets-for-datasets/

[37] The SL5 Task Force, "The Sensitivity Levels Framework (SenLs)," Nov. 2025. [Online]. Available: https://sl5.org/projects/sensitivity-levels-framework